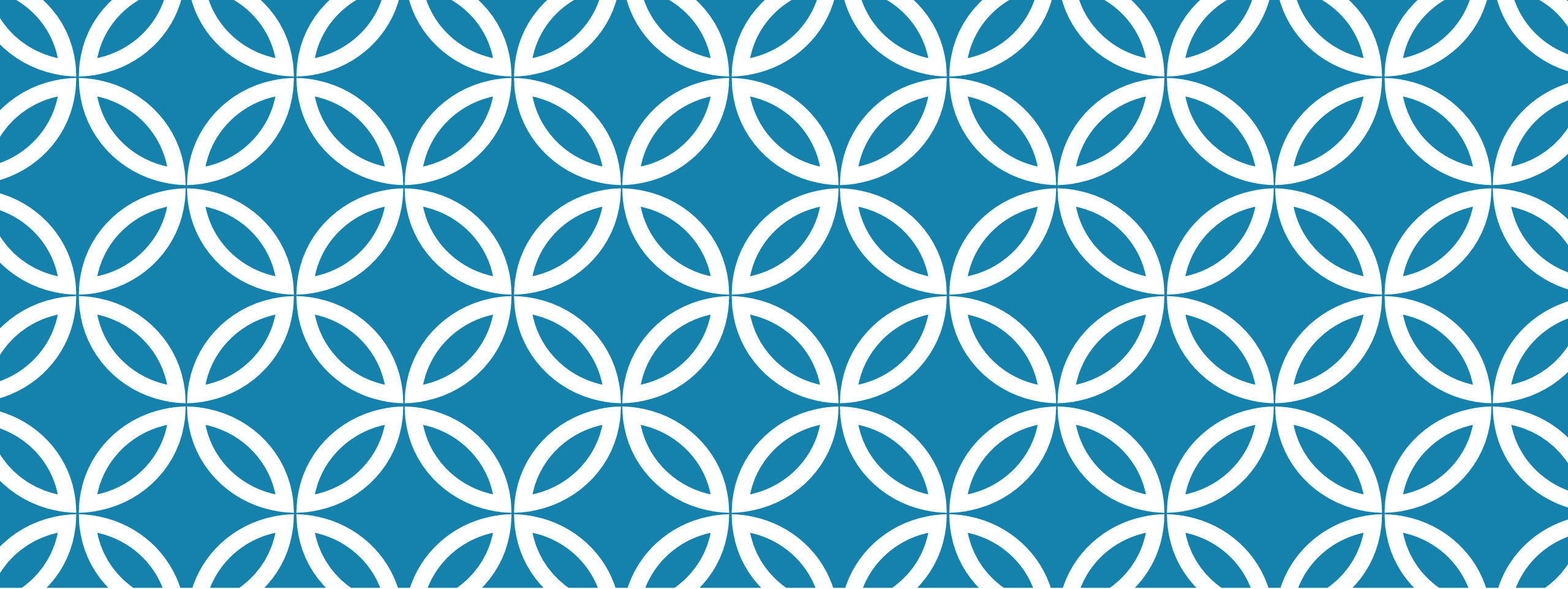
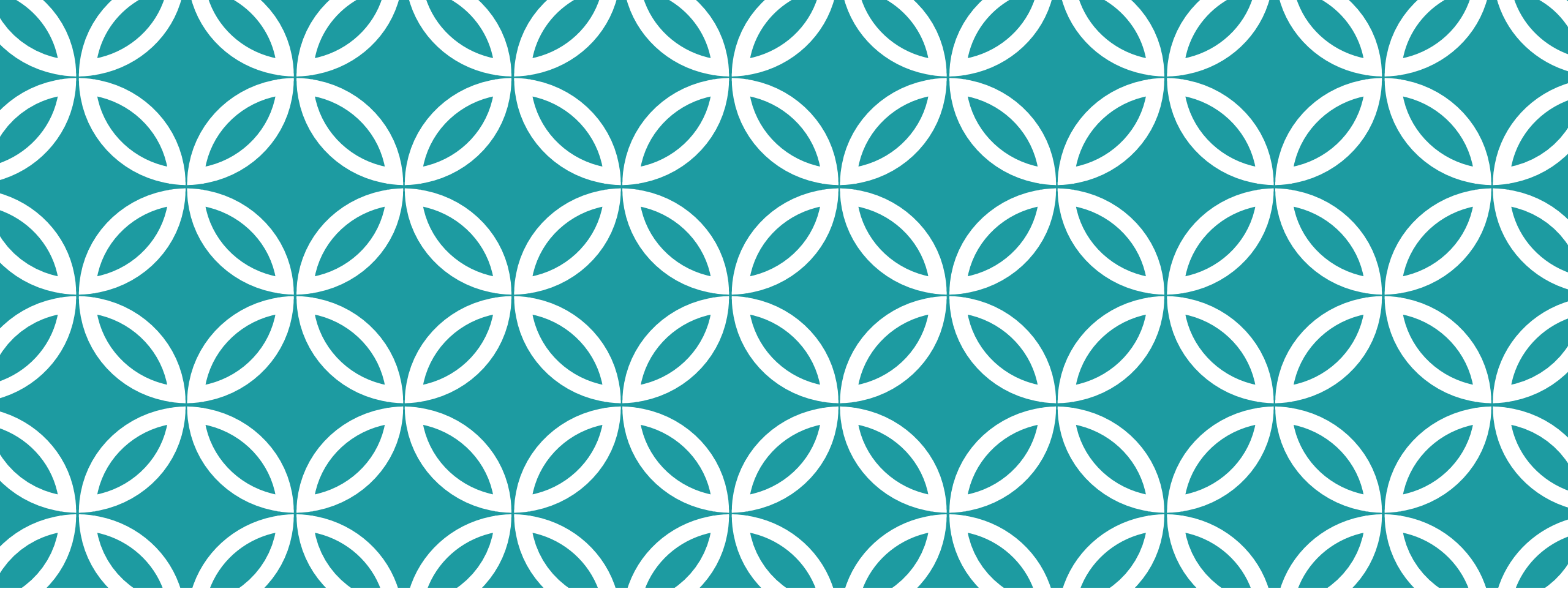




UF1. SEGURETAT FÍSICA, LÒGICA I LEGISLACIÓ

TAULA DE CONTINGUTS

1. Seguretat física, lògica i legislació
2. Principis Bàsics
3. Seguretat Passiva
4. Seguretat Lògica
5. Criptografia
6. Legislació
 - ◦ LOPD
 - ◦ Novetats RGPD
 - ◦ LOPD-GDD



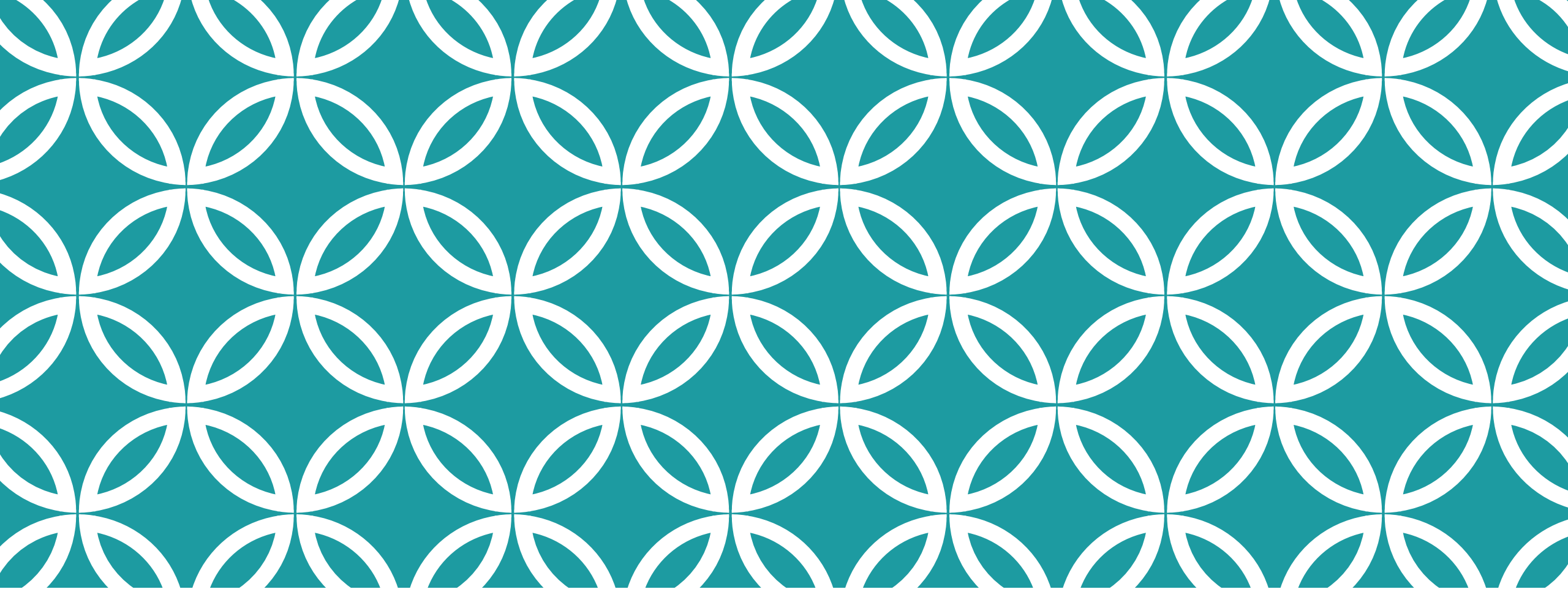
1. SEGURETAT FÍSICA, LÒGICA I LÈGISLACIÓ

1. SEGURETAT FÍSICA, LÒGICA I LEGISLACIÓ

Aquesta UF explica la seguretat informàtica a partir de la fiabilitat (garantia de la qualitat de servei), en aquest cas la qualitat de servei d'un sistema informàtic.

Posteriorment es defineixen les possibles vulnerabilitats d'un sistema com a mancances de seguretat en un determinat àmbit. En el sistema es podran detectar aquestes febleses i reaccionar per aplicar-hi contencions.

Alhora, s'explica que cal tenir en compte que existeix una legislació, unes normatives i una protecció de dades i que cal vetllar pel seu compliment, coneixent també quan un incident de seguretat ha de ser comunicat per tal d'inicia una investigació informàtica forense amb la finalitat de descobrir-ne l'autoria i poder iniciar els procediments legals corresponents.



2. PRINCIPIS BÀSICS DE LA SEGURETAT INFORMÀTICA



2. PRINCIPIS BÀSICS DE LA SEGURETAT INFORMÀTICA

La **Seguretat Informàtica** s'encarrega de protegir la integritat i la privacitat de la informació emmagatzemada en el sistema informàtic d'una organització.

No existeix cap tècnica que permeti assegurar la inviolabilitat d'un sistema, però sí encaminades a obtenir alts nivells de seguretat.

2. PRINCIPIS BÀSICS DE LA SEGURETAT INFORMÀTICA

Objectius principals:

- **Detectar** els possibles problemes i amenaces a la seguretat, minimitzant i gestionant els riscos.
- **Garantir** la utilització correcta dels recursos i les aplicacions del sistema.
- **Limitar** les possibles pèrdues i aconseguir la recuperació correcta del sistema en cas de patir un incident de seguretat.
- **Complir** amb el marc legal i amb els requisits imposats a nivell organitzatiu.

2. PRINCIPIS BÀSICS DE LA SEGURETAT INFORMÀTICA

La informació:

- La informació és avui dia un dels actius més importants de les organitzacions, i ha de protegir-se.
- La informació es troba en **diferents estats**: Mentre es processa, en transmissió i emmagatzemada.
- Existeix en **múltiples formes**: paper, emmagatzemada electrònicament, transmesa per correu o mitjans electrònics, parlada en una conversa o un vídeo, etc.
- Cada estat i forma disposa d'una sèrie d'**amenaces i vulnerabilitats** de diferents nivells contra les quals cal protegir-la
- Antigament tot era suport i paper, i la seguretat era principalment **física**. Actualment el primordial és el suport informàtic i la seguretat **lògica**.

2. PRINCIPIS BÀSICS DE LA SEGURETAT INFORMÀTICA

Amenaces:

- La informació i tots els suports que la sustenten en una organització (sistemes i xarxes) estan sotmesos cada vegada a més amenaces des de més

fonts.

- Les **clàssiques** amenaces: frau, espionatge, sabotatge, vandalisme, foc, inundacions, etc.
- Les **noves** amenaces: virus, hackers, negació de servei, etc.
- Les organitzacions depenen cada dia més dels seus sistemes d'informació, i **són més vulnerables**
- La majoria dels SI no han estat dissenyats amb criteris de seguretat (no era prioritari, ex. TCP/IP)

Posteriorment es veurà que el relacionat amb la Seguretat Informàtica (amenaces, vulnerabilitats, atacs, mesures de seguretat, etc) ha anat augmentant i modificant-se amb el temps, fet que fa necessari estar al dia en aquesta matèria. (Veure: [La ciberseguridad: una demanda creciente](#))

2.1 FIABILITAT

Un sistema és segur, és a dir **fiable**, si es poden garantir tres aspectes: **confidencialitat**, **integritat** i **disponibilitat**.

- **Confidencialitat:** propietat que garanteix que la informació és accessible només per aquells autoritzats a tenir accés. Ho podem entendre com la protecció de dades i d'informació intercanviada entre un emissor i un o més destinataris enfront de tercers.
- **Integritat:** propietat que busca mantenir les dades lliures de modificacions no autoritzades. La integritat d'un missatge s'obté per exemple, adjuntant-li un altre conjunt de dades de comprovació de la integritat: la signatura digital és un dels pilars fonamentals de la seguretat de la informació.
- **Disponibilitat:** capacitat que permet que la informació pugui ser accessible i es pugui utilitzar per els usuaris o processos autoritzats quan aquests ho requereixin.

En termes generals, hem d'aconseguir garantir aquests tres aspectes perquè hi hagi **seguretat** en el sistema.

2.1. FIABILITAT

Depenen de quin sigui l'us que se li doni a un sistema, als seus responsables els interessarà donar prioritat a un aspecte pel damunt dels altres.

Per exemple en un servidor de xarxa, se li donarà prioritat a la **disponibilitat** per davant de la confidencialitat i la integritat.

En un banc se li donarà prioritat a la **integritat**, davant de la disponibilitat o confidencialitat, ja que és menys greu que un usuari pugui llegir el saldo d'un altre a que el pugui modificar.

Un sistema militar donarà preferència a la **confidencialitat** sobre la disponibilitat o integritat d'aquests.

2.1. FIABILITAT

Complementant els tres aspectes anteriors hi han dos més que convé tenir en compte: Autenticació i No repudi.

Aquests, juntament amb els tres anteriors completen les sigles **CIDAN** (**C**onfidencialitat, **I**ntegritat, **D**isponibilitat, **A**utenticació i **N**o repudi)

- Autenticació: L'autenticació és un servei de seguretat que permet verificar la identitat. Una signatura digital és un mecanisme que assegura la identitat del signant del missatge i per tant la seva autenticitat.

2.1. FIABILITAT

- No repudi o irrenunciabilitat: servei de seguretat que permet provar la participació de les parts en una comunicació (servei estandaritzat en la ISO-7498-2).

Existiran dues possibilitats:

- **No repudi en origen**: L'emissor no pot negar que va enviar el missatge perquè el destinatari té proves de l'enviament, el receptor rep una prova infalsificable de l'origen de l'enviament, la qual cosa evita que l'emissor, de negar tal enviament, tingui èxit davant el judici de tercers. En aquest cas la prova la crea el propi emissor i la rep el destinatari.
- **No repudi en destinació**: El receptor no pot negar que va rebre el missatge perquè l'emissor té proves de la recepció. Aquest servei proporciona a l'emissor la prova que el destinatari legítim d'un enviament, realment ho va rebre, evitant que el receptor ho negui posteriorment. En aquest cas la prova irrefutable la crea el receptor i la rep l'emissor.

2.1. FIABILITAT

La possessió d'un document i la seva signatura digital associada serà prova efectiva del contingut i de l'autor del document.

Aplicant una mica la lògica podem crear una jerarquia amb les anteriors característiques:

**Disponibilitat +
Confidencialitat
Integritat
Autenticació
No repudi -**

És a dir, **la primera característica a garantir és la disponibilitat**. Si no tenim disponibilitat no poden haver-hi la resta de requisits, i així successivament.

2.2. ALTA DISPONIBILITAT

La Disponibilitat es refereix a l'habilitat de la comunitat d'usuaris per accedir al sistema, sotmetre nous treballs, actualitzar o alterar treballs existents o recollir els resultats de treballs previs i per tant si un usuari no pot accedir al sistema es diu que està no disponible.

L'Alta Disponibilitat és la garantia per l'usuari que quan vulgui accedir al sistema, aquest "sempre" estarà disponible.

Per tant la **Alta Disponibilitat** és la continuïtat operacional durant un període de temps donat.

2.2. ALTA DISPONIBILITAT

El terme **temps d'inactivitat (downtime)** és usat per definir quan el sistema no està disponible.

Podem dividir-lo en dos grups:

- Temps d'inactivitat planificat: períodes de temps en que cal deixar el sistema no disponible per l'usuari per poder realitzar accions necessàries per el correcte funcionament (actualitzacions del sistema que requereixin reiniciar, etc) i en els que decidim quan fer-ho.
- Temps d'inactivitat no planificat: períodes de temps en que el sistema deixa d'estar disponible sense haver-ho previst (errors de hardware, tall del subministrament elèctric, etc)

2.2. ALTA DISPONIBILITAT

La disponibilitat normalment es representa com un percentatge del temps (minuts) de funcionament respecte un any.

Tenint en compte que un any disposa d'uns 525.600 minuts, si el sistema es troba amb un temps d'inactivitat no planificat de 10 hores l'any, direm que tindrem un percentatge de disponibilitat de 99.88%:

$(\text{Minuts d'inactivitat} / \text{Minuts any}) * 100 =$

$= \text{Percentatge minuts inactivitat en un any} 100 - \text{Percentatge minuts inactivitat en un any} = \textbf{Percentatge disponibilitat en un any}$

2.2. ALTA DISPONIBILITAT

Percentatge disponibilitat en un any:

Els valors comuns de disponibilitat, conegut típicament com a nombre de "nous" per a sistemes *altament disponibles* són:

- **99,9%** = 43.8 minuts/mes o 8,76 hores/any ("tres nous")
- **99,99%** = 4.38 minuts/mes o 52.6 minuts/any ("quatre nous")
- **99,999%** = 0.44 minuts/mes o 5.26 minuts/any ("cinc nous")

Exemples d'Alta disponibilitat: control aeri, banca, sistemes militars, etc.

2.3. ELEMENTS VULNERABLES EN UN SISTEMA INFORMÀTIC

Els principals elements vulnerables en un SI són:

- **Hardware.**
- **Software.**
- **Dades.**

A vegades es parla d'un quart, que serien els elements fungibles (paper, impressores, ...)

2.3. ELEMENTS VULNERABLES EN UN SISTEMA INFORMÀTIC

El tema de seguretat s'ha de tractar genèricament, no individualment, ja que **la seguretat de tot el sistema és igual a la del seu punt més dèbil.**

No serveix crear una bona seguretat, si després els usuaris no ajuden.

Podem protegir el màxim el SI, però si un usuari es deixa la seva sessió oberta hi podrà accedir qualsevol i no haurà servit de res tota la seguretat del sistema.

Caldrà tenir un bon **nivell organitzatiu** amb unes **normes i pautes**.

Sistema de seguretat = TECNOLOGIA + ORGANITZACIÓ

2.3. ELEMENTS VULNERABLES EN UN SISTEMA INFORMÀTIC

Dels tres elements, **les dades** acostuma a ser el principal element a protegir, ja que acostuma a ser el principal objectiu de les amenaces, i el més important i difícil de recuperar per una organització.

Un sistema operatiu es pot restaurar des de el seu origen (DVD, xarxa, USB, etc.), en canvi les dades, requereixen una bona política de **còpies**, i tot i així es possible que s'acabi perden alguna informació.

Hem de tenir en compte a la hora de d'establir els criteris de seguretat, de contemplar els diferents **nivells de seguretat: locals, personals, individuals i globals.**

2.3. ELEMENTS VULNERABLES EN UN SISTEMA INFORMÀTIC

Segons això ens quedaria l'esquema següent (de més a menys profunditat):

**Hardware +
Sistemes Operatius
Comunicacions
Físiques
Organitzatives
Legals -**

És a dir, l'**element més crític a protegir** d'un sistema informàtic és el hardware.

2.4. AMENACES

Podem dividir-les en dos grups:

- Des de el punt de vista de **qui** o **què** les genera.
 - Físiques.
 - Persones (internes i externes).
 - Ambientals (Desastres naturals, incendis accidentals, tempestes i inundacions).
 - Lògiques.
 - Intencionades (malware).
 - Per error (bugs o forats).
- Des de el punt de vista de les **tècniques utilitzades en l'atac.**

2.4.1. AMENACES FÍSiques

Poden estar provocades per persones, ja siguin internes de la organització o externes(hackers, crackers, ...) o per aspectes ambientals (no serveix protegir-nos contra atacs de persones, si es produeix un incendi i se'ns destrueix tot).

- **Persones**

- ***Internes:*** Persones que treballa dins una organització i que aprofita tot el coneixement que té d'aquesta per produir un atac, o per un error o desconeixement de les normes de seguretat (no cal que sigui intencionat, per considerar-se una amenaça).

- ***Externes:***

- ***Hackers***

- ***Newbie:***

- ***Wannaber***

- ***Lammer o Script-Kiddies.***

- ***Phreaker***

- ***Samurai***

- ***Pirates***

- informàtics***

2.4.1.2. AMENACES FÍSiques PERSONES EXTERNES

▪ Hackers:

Són experts que aprofiten qualsevol forat en la seguretat per accedir al sistema d'una organització.

Si aquest accés és per realitzar alguna acció destructiva (esborrar dades, agafar informació, ...) els anomenarem **crackers**.

Hi han tres grups de hackers:

- **White hat** (depuren i arreglen errors o forats en el sistema).
- **Black hat** (els que són destructius)
- **Grey hat** (que estan entre mig, fan coses bones i a vegades traspassen els límits).

2.4.1.2. AMENACES FÍSiques PERSONES EXTERNES

- ***Newbie***: Algú que comença però no té gaires coneixements.
- ***Wannaber***: Hacker en potència, però que encara no té un reconeixement.
- ***Lammer* o *Script-Kiddies***: Es creuen hackers, però l'únic que fan és buscar i descarregar programes de hacking per després executar-los.
- ***Phreaker***: De phone freak ("monstre telefònic"). Són persones amb coneixements amplis tant en telèfons modulars (TM) com en telèfons mòbils.

2.4.1.2. AMENACES FÍSiques PERSONES EXTERNES

- ***Samurai***: Normalment és algú contractat per investigar fallades de seguretat, que investiga casos de drets de privadesa, estigui emparat per la primera esmena nord-americana o qualsevol altra raó de pes que legítimi accions semblants. Els samurais menyspreen als crackers i a tot tipus de vándals electrònics. També es dediquen a fer i dir com saber sobre la seguretat amb sistemes en xarxes.
- ***Pirates informàtics o ciberdelinqüents***: persones dedicades a realitzar actes delictius i perseguits legalment (com la còpia i distribució de software, música, pel·lícules, etc, de forma il·legal o frau bancari o estafes econòmiques).

2.4. AMENACES FÍSiques

- **Ambientals:** Afecten a les instal·lacions i/o hardware contingut en elles i suposen el primer nivell de seguretat a protegir per a garantir la disponibilitat dels sistemes. Ho veurem amb més profunditat en la Seguretat Passiva.

2.5. LÒGIQUES

Quan parlem d'amenaques lògiques ens referim a software o codi que d'una manera o una altra poden afectar o malmetre el nostre sistema. Ja sigui de forma malintencionada (malware) o simplement per error (bugs o forats):

- ***Eines de seguretat***: de la mateixa forma que es poden utilitzar per detectar i solucionar problemes de seguretat, poden ser utilitzades per detectar i aprofitar aquests problemes.
- ***Rogueware***: falsos problemes de seguretat. Són falsos antiespies o antivirus (anomenats també Rogue, FakeAVs, Badware, Sacreware,....)
- ***Portes del darrera o backdoors***: És un programari que permet l'accés al sistema operatiu de l'ordinador ignorant els procediments normals d'autenticació. Moltes vegades son accessos ràpids que es deixen els programadors per accedir a un sistema sense donar moltes voltes i que aprofiten els codis maliciosos per entrar en un sistema, a vegades només és una part del sistema que no s'ha protegit adequadament. Els principals programes d'accés als backdoors són: [Back_Orifice](#), [NetBus](#) i [Subseven](#).

2.5. LÒGIQUES

- ***Virus***: Codi maliciós que s'inserta en un programa (hoste) i quan aquest s'executa activa el virus. Ho veurem amb més detall en la part del malware.
- ***Cucs o Worms***: Programa que s'executa, es propaga a si mateix a través de la xarxa, normalment a través del correu electrònic o [Spam](#).
- ***Troians***: Programes dissenyats per fer veure que són una cosa i en realitat contenen codi maliciós.
- ***Programes conill o bacteris***: Programes que no fan res més que reproduir-se fins que colapsen el sistema (memòria, disc dur, ...)
- ***Canals coberts (Covert Channel)***: són ports de comunicació que permeten a un procés receptor i a un emissor intercanviar informació de manera que violi la política de seguretat del sistema; essencialment es tracta d'un mètode de comunicació que no és part del disseny original del sistema però que pot utilitzar-se per transferir informació a un procés o usuari que a priori no estaria autoritzat a accedir a aquesta informació.

2.6. TÈCNIQUES D'ATAC

Entre les moltes tècniques d'atac ens podem trobar:

- **Malware:** Programes malintencionats, els veurem amb més detall més endavant.
- **Enginyeria social:** Obtenir informació confidencial (per exemple credencials) a través de la manipulació i la confiança dels seus usuaris legítims.
- **Scam:** Estafa electrònica per mitjà de donacions, transferències, compra de productes fraudulents, etc.
- **Spam:** Correu o missatge basura, no desitjat o no sol·licitat, habitualment de tipus publicitari. Acostuma a ser una de les tècniques de la enginyeria social
- **Sniffing:** Rastrear monitoritzant el tràfic d'una xarxa per fer-se amb informació confidencial.
- **Spoofing:** Suplantació d'identitat o falsificació (IP, MAC, taula ARP, web,)

2.6. TÈCNIQUES D'ATAC

- **Pharming:** És un atac al nostre ordinador amb la intenció de redirigir el trafic d'un lloc web a un altre de maliciós. Es pot fer canviant el fitxer hosts en l'ordinador de la víctima o aprofitant alguna vulnerabilitat del programari del servidor de DNS.
- **Phishing:** És un frau que es fa amb un correu electrònic o missatgeria instantània amb el que es demanen dades sobre les targetes de crèdit, claus bancàries, o altres tipus d'informació. Els missatges empren tot tipus d'arguments relacionats amb la seguretat de l'entitat per justificar la necessitat d'introduir les dades d'accés.
- **Password cracking:** És un procés informàtic que consisteix a desxifrar la contrasenya de determinades aplicacions seleccionades per l'usuari. Es busca codificar els codis de xifrat en tots els àmbits de la informàtica. Es tracta del trencament o desxiframent de les claus (passwords).

2.6. TÈCNIQUES D'ATAC

- **Botnet:** És un grup d'ordinadors (anomenats bots o zombies) connectats a Internet que involuntàriament, un cop han estat infectats amb un virus, un cuc o un troià, poden ser controlats remotament per realitzar tasques sense l'autorització del propietari i sense que aquest se n'adoni. Les botnets poden arribar a tenir milers o centenars de milers d'ordinadors sota control i es fan servir per a desfermar, per exemple, atacs massius de denegació de servei, enviar onades de correu brossa (spam) o infectar a altres ordinadors poc protegits.
- **Denegació de servei o Denial of Service (DoS):** Es tracta d'atacar a un servei del servidor com podria ser el servidor web ubicat al port 80, fent servir un bon nombre de màquines atacant al servidor, mitjançant trames IP amb flags erronis, pertal que el servidor augmenti el seu temps de processador, així farem que deixi de donar servei, ja que es quedarà sense memòria física.

2.7. PROTECCIÓ

Per protegir un sistema, el que hem de fer es **analitzar** les *possibles amenaces*, les *pèrdues* que es podrien generar i la *probabilitat que això succeeixi*.

La forma comú de fer aquests anàlisis es mitjançant **auditories de seguretat**. Un cop tenim la auditoria hem de dissenyar el sistema de seguretat que hi aplicarem.

Auditoria

Els objectius d'una auditoria són:

- Revisar la seguretat dels entorns i sistemes.
- Verificar el compliment de la normativa i legislació vigents.
- Elaborar un informe independent.

2.7.1. PROTECCIÓ. AUDITORIA

Es realitza en base a un patró o conjunt de directrius o bones pràctiques suggerides.

Existeixen uns estàndars que es poden seguir com a guia:

- **COBIT** : Objectius de Control de les Tecnologies de la informació.
- **ISO27002**: Codi internacional de **bones pràctiques** de seguretat de la informació.
- **ISO27001**: Defineix els requisits de les **auditories** i sistemes de gestió de seguretat.

No son excloents un dels altres, sinó que són completament complementaris.

2.7.1. PROTECCIÓ. AUDITORIA

Es realitza en base a un patró o conjunt de directrius o bones pràctiques suggerides.

Existeixen uns estàndars que es poden seguir com a guia:

- **COBIT** : Objectius de Control de les Tecnologies de la informació.
- **ISO27002**: Codi internacional de **bones pràctiques** de seguretat de la informació.
- **ISO27001**: Defineix els requisits de les **auditories** i sistemes de gestió de seguretat.

No son excloents un dels altres, sinó que són completament complementaris.

2.7.1.1. FASES D'AUDITORIA

Els serveis de l'auditoria consta de les **següents fases**:

- Enumerar sistemes operatius, serveis, aplicacions, topologies i protocols de xarxa.
- Detecció, comprovació i avaluació de vulnerabilitats.
- Mesures específiques de correcció.
- Recomanacions sobre implantació de mesures preventives.

2.7.1. TIPUS D'AUDITORIA

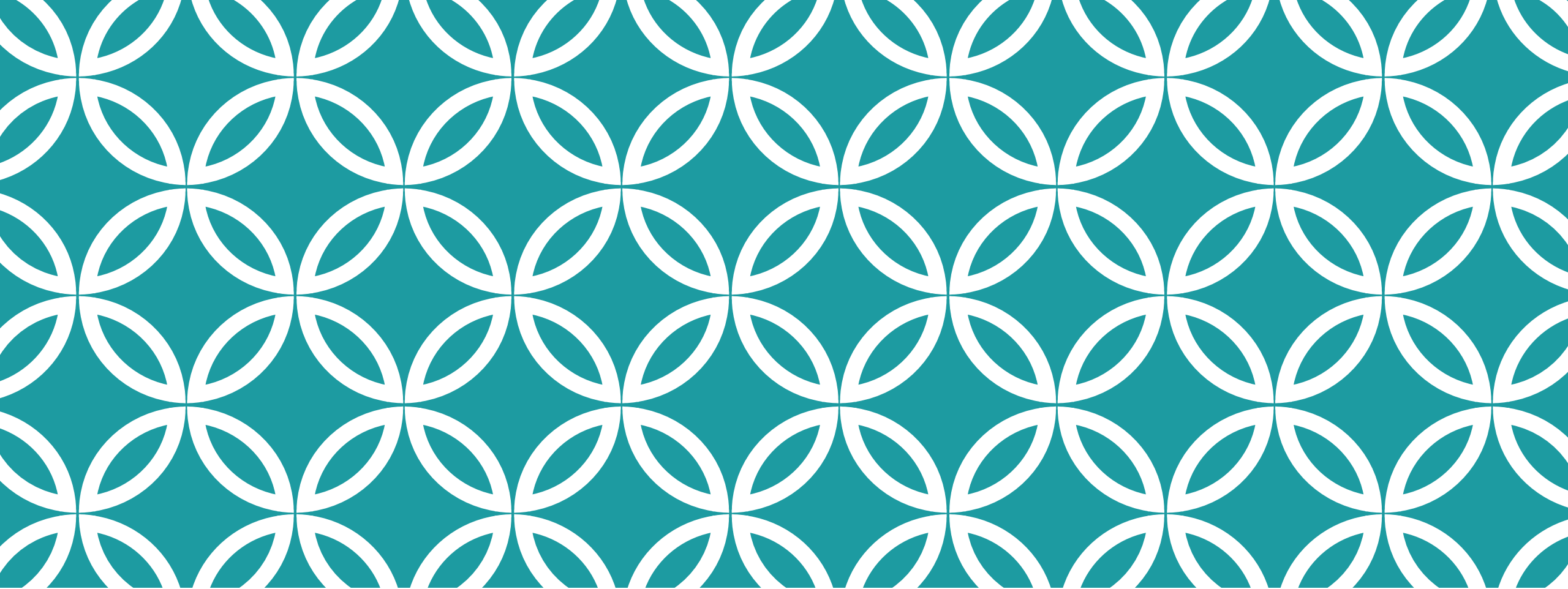
- **Auditoria de seguretat interna:** a nivell de seguretat de la xarxa local i de la organització a nivell intern.
- **Auditoria de seguretat perimetral:** estudi del perímetre de la xarxa local o corporativa connectada a xarxes públiques.
- **Test d'intrusió:** S'intenta accedir al sistemes per comprovar el nivell de resistència a la intrusió no desitjada.
- **Anàlisis forense:** anàlisis posterior d'incidents, es tracta de veure com s'ha penetrat en el sistema i els danys ocasionats (si això a causat la inoperabilitat del sistema es denomina anàlisi **post mórtem**).
- **Auditoria de codi d'aplicacions:** anàlisi del codi independentment del llenguatge utilitzat.

2.8. MESURES DE SEGURETAT

A partir dels resultats de les auditories, hem de dissenyar una **política de seguretat** que defineixi responsabilitats i les **regles a seguir** per evitar les amenaces o minimitzar els seus efectes.

Més endavant veurem les diferents mesures de seguretat:

- Segons el recurs a protegir:
 - *Seguretat física*: **hardware**
 - *Seguretat lògica*: **software**
- Segons el moment en el que es posen en marxa les mesures:
 - *Seguretat activa*: **preventiva**
 - *Seguretat passiva*: **correctiva**



3. SEGURETAT PASSIVA



3.1. SEGURETAT PASSIVA. INTRODUCCIÓ

Durant les dècades de 1960 i 1970, la seguretat física dels equips informàtics era una tasca molt menys complexa que avui en dia. Els ordinadors només estaven a l'abast de grans corporacions que no n'acostumaven a tenir més d'un.

El maquinari ocupava sales enormes que eren a les entranyes dels edificis de les grans corporacions i, tot i accedir-hi, molt poca gent sabia què fer-ne.

A l'actualitat gairebé tothom té un ordinador en l'anomenada societat del primer món. Hi ha persones que disposen de portàtils, ordinadors de butxaca i altres dispositius mòbils. Gràcies a les tecnologies sense fil es pot accedir a qualsevol equip sense tenir-hi accés físic. **Protegir** tots aquests dispositius contra robatoris, frau, sabotatge, vandalisme i altres riscos **és una tasca cada vegada més complexa i costosa.**

La tecnologia i els entorns esdevenen més complexos amb la qual cosa apareixen nous riscos. Moltes empreses han tingut robatoris de dispositius o fugues d'informació i, en els pitjors casos, crims com ara assalts a punta de canó o tirotejos d'antics empleats ressentits.

3.1. INTRODUCCIÓ

Protegir físicament els equips informàtics és una tasca fonamental com a base de la seguretat informàtica global. Per aconseguir uns bons resultats cal aplicar una estratègia de defensa en capes. Així es desplegarà tota una sèrie de controls i mesures que combinats garanteixin uns bons nivells de seguretat.

Un exemple d'estratègia de **defensa en capes** seria instal·lar una tanca perimetral, seguida dels murs de les instal·lacions, llavors un accés mitjançant targeta, més una vigilància de guardes de seguretat.

Tenir uns nivells alts de seguretat física pot ser costós i impactar negativament en la productivitat. No sempre és necessari tenir una seguretat digna del Pentàgon, cal **estudiar i mesurar correctament** quines són les mesures de seguretat que cal instal·lar.

3.1. INTRODUCCIÓ

A l'hora d'elaborar una estratègia de protecció física dels equips informàtics, cal identificar les amenaces i els riscos que cal avaluar. Posteriorment, s'apliquen les mesures de seguretat pertinents per tal de **minimitzar** aquests **riscos i amenaces**.

Per tant direm que **la seguretat passiva és correctiva** ja que intenta minimitzar l'impacte i els efectes causats per "*accidents*", es a dir, es consideren mesures o accions posteriors a un atac o incident.

Un exemple de possibles problemes i les solucions proposades seria:

3.2. EMPLAÇAMENTS

Quan una companyia decideix construir unes instal·lacions noves s'han de tenir en compte molts factors abans de posar la primera pedra.

Normalment, el preu del sòl, la proximitat de clients i de distribuïdors i les estratègies de màrqueting són factors rellevants, però des del punt de vista de la seguretat també s'han de tenir en compte altres consideracions.

Algunes empreses i organitzacions que tracten amb dades d'alt secret o confidencials construeixen les instal·lacions a **llocs recòndits** per tal de no cridar l'atenció de possibles persones malintencionades. Per aconseguir poca visibilitat de les instal·lacions de vegades es construeix a **ubicacions que no són d'accés fàcil** i, a més a més, s'evita posar-hi logos, cartells de la companyia o qualsevol tipus d'informació que doni detalls de l'activitat que es produeix dins de les instal·lacions.

És important avaluar la **proximitat** de les instal·lacions respecte a les **forces de seguretat i ordre**, els bombers i les instal·lacions sanitàries en funció de l'activitat a què es dediqui l'empresa. Així, doncs, per a una empresa que tracti amb materials inflamables serà un requisit important la proximitat a una estació de bombers.

3.2. EMPLAÇAMENTS

L'ús de **xarxes sense fil**, tot i que estiguin xifrades, és una de les fonts que utilitzen els intrusos per captar informació des de fora de les instal·lacions. Per tal d'evitar la captació il·legal d'informació que viatja per ones de vegades es busquen emplaçaments on les característiques de la zona facin més difícil la propagació de les ones. Com que això no sempre és possible una alternativa és construir **gàbies de Faraday** (que aïllen les ones electromagnètiques).

Els **elements externs** són un factor important que cal considerar en la ubicació de les instal·lacions. Cada cop més, la temperatura i el clima són factors que cal tenir en compte, ja que el maquinari és molt sensible a temperatures elevades i els costos de refrigeració són cada cop més importants.

3.2. EMPLAÇAMENTS

La llista següent és un recull de factors que cal tenir en compte de cara a l'elecció de l'emplaçament de les instal·lacions:

- **Visibilitat**

- Terrenys circumdants
- Cartells i logos de l'empresa
- Tipus d'empreses que hi ha als voltants
- Població de la zona

- **Factors Externs**

- Taxes de crim i de terrorisme
- Proximitat a estacions de policia, bombers i instal·lacions mèdiques

3.2. EMPLAÇAMENTS

- **Accessibilitat**

- Accés per carretera
- Trànsit
- Proximitat a aeroports, estacions de tren i autopistes

- **Desastres Naturals**

- Probabilitat d'inundacions, tornados, terratrèmols o huracans
- Riscos del terreny: allaus, despreniment de roques.

3.2. EMPLAÇAMENTS

Emplaçaments remots d'instal·lacions

Avui en dia hi ha empreses tecnològiques de primer ordre mundial que consideren l'elecció de la ubicació de les instal·lacions un factor diferencial i central dins de l'estratègia de la companyia.

*Per disminuir costos en refrigeració de màquines i tenir més seguretat hi ha empreses que construeixen **grans parcs de servidors a mines de carbó abandonades**. D'altres, en canvi, ho fan a llocs recòndits de **l'estepa siberiana**.*

*Un dels exemples més curiosos d'instal·lacions a llocs remots és el d'un dels gegants d'Internet que està desplegant parcs de servidors en **vaixells a alta mar**. S'aprofita el moviment produït per les onades com a font energètica i la proximitat d'aigua per a la refrigeració de les màquines. Com que la localització dels vaixells és secreta la seguretat de les màquines és molt elevada.*

3.2. EMPLAÇAMENTS

Emplaçaments remots d'instal·lacions

Avui en dia hi ha empreses tecnològiques de primer ordre mundial que consideren l'elecció de la ubicació de les instal·lacions un factor diferencial i central dins de l'estratègia de la companyia.

*Per disminuir costos en refrigeració de màquines i tenir més seguretat hi ha empreses que construeixen **grans parcs de servidors a mines de carbó abandonades**. D'altres, en canvi, ho fan a llocs recòndits de l'**estepa siberiana**.*

*Un dels exemples més curiosos d'instal·lacions a llocs remots és el d'un dels gegants d'Internet que està desplegant parcs de servidors en **vaixells a alta mar**. S'aprofita el moviment produït per les onades com a font energètica i la proximitat d'aigua per a la refrigeració de les màquines. Com que la localització dels vaixells és secreta la seguretat de les màquines és molt elevada.*

3.3. SEGURETAT AMBIENTAL

No tenir uns controls adequats de les condicions ambientals pot comportar danys tant a maquinari com a persones. L'aturada de certs serveis a causa d'aquestes circumstàncies pot provocar resultats desastrosos.

Tenir els sistemes elèctrics, de temperatura, de ventilació, d'aire condicionat i de prevenció d'incendis perfectament ajustats és molt important per tenir uns nivells de seguretat correctes.

Per tal de minimitzar riscos, durant la fase de construcció de les instal·lacions l'equip de seguretat s'ha d'encarregar de revisar que les canonades d'**aigua** i de **gas** estiguin dotades de **vàlvules de seguretat** que impedeixen la propagació en cas de fuites.

3.3. SEGURETAT AMBIENTAL

La **temperatura** és un element primordial que cal tenir controlat. La majoria dels equips electrònics ha de treballar en un interval de temperatures controlat per tal de funcionar correctament.

Temperatures excessives poden provocar desperfectes irreparables en els components electrònics. A més de controlar la temperatura ambiental, s'ha de revisar periòdicament el funcionament correcte dels **ventiladors** i d'altres components de **refrigeració** dels equips.

Nivells d'humitat inapropiats poden ser una font de danys en equips electrònics. Uns nivells de humitat alts produeixen corrosió en els components elèctrics, mentre que entorns massa secs provoquen massa electricitat estàtica que pot provar curtcircuits.

3.3. SEURETAT AMBIENTAL

Condicions elèctriques

Per a la majoria d'instal·lacions és necessari disposar d'un **sistema d'alimentació** que garanteixi la continuïtat del servei en cas de problemes externs d'alimentació. Per a això, es fan servir els mecanismes que veurem en la part de sistemes d'alimentació ininterrompuda.

S'ha de controlar que no hi hagi interferències produïdes pels sistemes d'alimentació. Hi ha dos tipus d'interferències: **interferències electromagnètiques** i interferències de **ràdio**.

Si els cables utilitzats no estan **aïllats** degudament poden produir interferències electromagnètiques els uns amb els altres. Les vibracions produïdes per **motors** són una altra font comuna d'interferències electromagnètiques.

Qualsevol element que produeixi ones de ràdio és una possible font d'interferències de ràdio. La llum produïda pels **fluorescents** és la font més comuna d'interferència electromagnètica. Per això, s'evita passar cablejat per zones pròximes a fluorescents.

3.3. SEGURETAT AMBIENTAL

Ventilació

Els sistemes de ventilació tenen diversos requeriments que s'han de complir per tal de garantir un entorn segur i confortable. Per mantenir la qualitat de l'aire cal tenir un **sistema d'aire condicionat de circuit tancat**.

Un sistema d'aire condicionat de circuit tancat **recicla l'aire** que hi ha dins l'edifici un cop està filtrat degudament en comptes d'expulsar-lo a l'exterior.

*Els **sistemes de ventilació** a més de tenir la funció de refrigerar també són importants per evitar l'acumulació de pols i d'altres agents contaminants.*

La pols pot obstruir els ventiladors que s'encarreguen de la refrigeració interna dels equips, mentre que la concentració excessiva de certs gasos pot accelerar la corrosió dels equips.

3.3. SEGURETAT AMBIENTAL

Mesures de prevenció d'incendis

Un incendi presenta un risc molt important de seguretat tan pel que fa a possibles **destrosses de maquinari** com al perill que comporta per a les **vides humanes**.

El fum, les altes temperatures i els gasos emesos en un incendi poden crear resultats devastadors; per tant, cal tenir-ho en compte a l'hora d'escollir o de dissenyar unes instal·lacions.

El foc comença per la combustió d'algun **element inflamable**. Les possibles causes de l'inici d'un incendi són moltes: un curtcircuit, materials combustibles indegudament emmagatzemats, una cigarreta mal apagada, sistemes de calefacció defectuosos...

3.3. SEGURETAT AMBIENTAL. MESURES DE PREVENCIÓ D'INCENDIS

*Perquè un foc es propagui calen dues coses: **combustible i oxigen**.*

El combustible pot ser paper, fusta, líquids inflamables...

Com més combustible per metre quadrat hi hagi més ràpid es propagarà un incendi.

*Per tant, és molt important el disseny correcte de les zones d'emmagatzematge dels edificis per tal de **minimitzar l'acumulació d'elements que puguin servir de combustible en un incendi**.*

3.3. SEGURETAT AMBIENTAL.

Detectors d'incendi

Hi ha diversos tipus de sistemes **detectors** d'incendi, alguns de **manuals** i d'altres d'**automàtics**. Els **manuals** consisteixen en **activadors d'alarmes** que són accionades quan algú detecta un possible incendi. Els **automàtics** tenen una sèrie de **sensors** que reaccionen davant de la presència de foc o de fum.

Els sistemes detectors d'incendi per fum són sistemes òptics que detecten la presència de fum en funció de les variacions de llum. Consisteixen en un emissor que envia un feix de llum a un receptor col·locat a una certa distància (normalment al sostre de la sala). Quan el receptor detecta una **variació en la intensitat del feix de llum** vol dir que hi ha partícules de fum en suspensió.

Un sistema de detecció d'incendis molt bàsic però efectiu és l'ús de **sensors de temperatura**. En cas que els sensors detectin un augment desmesurat de la temperatura, llavors llencen un senyal d'alarma. És molt important la col·locació correcta d'aquests sensors perquè siguin efectius.

3.3. SEURETAT AMBIENTAL.

Sistemes d'extinció

Els sistemes inhibidors d'incendi són els que permeten l'eradicació de focs. Poden ser elements manuals com ara extintors o mànegues d'aigua, o bé automàtics com dispersors d'aigua o de gasos que provoquen l'extinció del foc.

El **CO2** és un dels gasos utilitzats per a l'extinció d'incendis. Provoca l'eliminació de l'oxigen disponible, la qual cosa deixa el foc sense un dels elements necessaris per continuar combustionant. El problema que té és que **no es pot aplicar si hi ha persones** a les dependències, ja que les deixaria sense oxigen per respirar. Hi ha certes **escumes** que també tenen la capacitat de deixar el foc sense oxigen per a la combustió. Són formades per aigua i certs agents que permeten que l'escuma floti sobre les substàncies que cremen, exclòs l'oxigen.

3.3. SEGURETAT AMBIENTAL. SISTEMES D'EXTINCIÓ

Gas haló

El gas haló era un dels compostos més utilitzat en els sistemes d'extinció de focs dels centres de dades per a l'eliminació d'incendis. Aquest gas té la capacitat d'interferir amb la química de la combustió, es barreja ràpidament amb l'aire i no causa cap dany en el maquinari de les instal·lacions.

Avui en dia ja no es fabriquen més sistemes d'extinció basats amb aquest compost doncs es va descobrir que el gas haló emetia clorofluorocarboni (CFC) que és un compost que fa malbé la capa d'ozó.

Hi ha diferents tipus de foc en funció del material que està en combustió. Segons el tipus de foc, s'ha d'aplicar una mesura d'extinció d'incendi o una altra.

3.4. RISCOS I AMENACES

A l'hora de planificar una estratègia per protegir els nostres béns, s'han d'avaluar quines són les *amenaces* i els *riscos* que els poden afectar.

Amenaça és qualsevol vulnerabilitat que pugui ser explotada per un atacant.

Un **risc** és la probabilitat que un atacant descobreixi una amenaça i l'exploti.

La seguretat física és el compendi de recursos, processos, tasques, equips i personal dedicats a protegir els recursos d'una empresa.

3.4. RISCOS I AMENACES

Les **amenaces** poden ser **internes o externes**.

Una amenaça **interna** es pot deure a un incident fortuït, com un incendi o una fuga d'aigua, o bé ser malintencionada, produïda per un empleat de la mateixa empresa.

Les amenaces internes poden ser difícils de controlar, perquè els treballadors d'una empresa tenen accés a informació i a coneixements que dificulten la protecció dels béns.

Les amenaces **externes** són originades per atacants aliens a l'empresa que volen o bé apoderar-se de béns i de coneixements, o bé malmetre recursos de l'empresa. Hi ha organitzacions que són més sensibles que altres a atacs.

És molt important fer una anàlisi de riscos per avaluar quin nivell de seguretat és el requerit per a cada cas. El centre de dades d'una seu governamental requerirà uns nivells de seguretat diferents que el servidor d'una distribuïdora de discos.

3.5. MESURES DE SEURETAT

La protecció física és una combinació de mecanismes que minimitzen els riscos de possibles atacs i, en cas que succeeixin, en disminueixen el dany.

*L'estratègia de protecció que cal seguir s'ha de decidir després de fer una **anàlisi** de riscos, **identificar** les vulnerabilitats i l'**impacte** que tenen.*

Podem dividir les mesures de seguretat en diverses categories segons la finalitat que tenen:

- Mesures dissuasives
- Dificultats en l'accés a personal no autoritzat
- Detecció d'intrusos
- Avaluació d'incidències

3.5. MESURES DE SEGURETAT

1. Mesures dissuasives

Moltes vegades es produeixen atacs perquè l'amenaça que es vol explotar és molt evident o simplement ho sembla.

La finalitat de les mesures dissuasives és desplegar tota una sèrie d'elements visibles per a possibles atacants que els faci canviar d'opinió.

En alguns casos, n'hi ha prou de trencar una simple finestra per accedir a equips i informació aliena. Posar un sistema d'alarma contra aquest risc i un cartell que indiqui que hi ha una alarma activada pot evitar que possibles atacants tinguin males intencions.

Hi ha molts elements que es poden fer servir com a mesures dissuasives, els més comuns són senyals d'alerta visibles, disposar de guardes de seguretat, de gossos, de tanques, d'alarmes...

3.5. MESURES DE SEURETAT

Les mesures dissuasives són:

- Tanques
- Murs
- Barrots
- Guardes de seguretat
- Gossos
- Senyals d'alerta
- Il·luminació nocturna
- ...

3.5. MESURES DE SEGURETAT

2. Dificultats d'accés a personal no autoritzat

Una funció que ha de complir un pla de protecció física és disposar de mesures que dificultin l'accés a personal no autoritzat. L'objectiu d'aquestes mesures és guanyar temps perquè, en cas que hi hagi un possible atac, es disposi de prou temps per aplicar les contramesures que siguin convenientes.

Un dels mecanismes més econòmics i utilitzat per dificultar l'entrada d'atacants és l'ús de cadenats. Si uns atacants trenquen una finestra i entren a unes instal·lacions, el temps que necessiten per desactivar els cadenats pot ser crucial perquè arribin les forces de seguretat.

Hi ha mecanismes molt complexos per dificultar que els atacants arribin al bé que volem protegir.

Instal·lacions d'alta seguretat, com agències d'investigació, segueixen estratègies que provenen del camp militar. En general, disposen de sistemes de protecció per capes, de manera que com més gran és la seguretat que es vol desplegar més capes de control s'han de superar per arribar-hi.

3.5. MESURES DE SEGURETAT. DIFICULTATS D'ACCÉS A PERSONAL NO AUTORITZAT

Man traps

Mantrap és un anglicisme que traduït literalment vol dir 'trampa per a persones'. És un **mètode de control d'accés** que **impedeix** que personal no autoritzat que entri a unes instal·lacions en **pugui escapar**.

Consisteix en una habitació amb dues portes. La primera porta està tancada, una persona s'identifica i és autenticada per un guarda de seguretat que li permet accés a la sala. Un cop s'accedeix a la sala, les dues portes es tanquen i per obrir la segona porta cal superar un mètode d'autenticació robust, com un control biomètric, o l'ús d'una targeta d'autenticació més contrasenya. En cas que no es pugui superar el control l'intrús queda atrapat a la sala.

3.5. MESURES DE SEGURETAT. DIFICULTATS D'ACCÉS A PERSONAL NO AUTORITZAT

Les dificultats d'accés a personal no autoritzat són:

- Cadenats
- Controls d'accés:
 - Biomètrics
 - Amb targeta intel·ligent
 - Amb teclat numèric
 - Seguretat perimetral
- Mantraps
- ...

3.5. MESURES DE SEGURETAT

3. Detecció d'intrusos

Els **sistemes de detecció d'intrusos** s'utilitzen per detectar accessos no autoritzats i alertar el personal competent de l'incident. Es divideixen en dues categories: els que utilitzen sensors interns o els que utilitzen sensors externs.

El mecanisme bàsic consisteix a detectar canvis en l'ambient que són indicadors que s'està produint algun tipus d'intrusió. Els canvis en l'ambient poden ser lumínics, sonors, de moviment, electromagnètics... Així, un soroll o una ombra poden delatar un intrús.

3.5. MESURES DE SEGURETAT. DETECCIÓ D'INTRUSOS

Els IDS (Intrusion Detection System, sistemes de detecció d'intrussos) són cars i requereixen una intervenció humana per actuar vers les alarmes.

És important que disposin d'un sistema d'alimentació propi perquè si no, deixant sense llum l'edifici, n'hi ha prou per evitar els IDS.

Els sistemes de detecció d'intrusos són:

- Sensors de detecció interns
- Sensors de detecció externs (sensors perimetrals)
- Detecció de canvis en l'ambient:
 - Lumínics
 - Acústics
 - De moviment
 - De camps electromagnètics

3.6. AVALUACIÓ D'INCIDÈNCIES

És força habitual que en el nostre sistema de seguretat hi hagi falsos positius, cosa que vol dir que salten alarmes quan realment no s'està produint cap incident. Si cada vegada que salta una alarma s'avisa les forces de seguretat això por representar un problema.

Hi ha d'haver un protocol que permeti que cada vegada que hi hagi una incidència es pugui avaluar si realment es tracta d'un fals positiu o d'un atac real.

Normalment, la persona que monitoritza les alarmes és un guarda que no té més informació que un punt verd o vermell en un monitor. És recomanable redactar una sèrie de procediments que cal seguir quan apareix una alarma, i també tenir una estructura de comunicació.

3.6. AVALUACIÓ D'INCIDÈNCIES

L'estructura de comunicació indica a qui s'ha d'avisar per a cada incidència que es produeixi. Així, si hi ha l'alarma d'un vidre trencat pot ser suficient que un guarda vagi a inspeccionar la zona, si hi ha una alerta de foc a la sala de servidors trucar als bombers...

Els sistemes d'avaluació d'incidències són:

- Monitoratge dels sistemes d'alarmes
- Procediments per a casos d'emergència
- Estructura de comunicació

3.7. SISTEMES D'ALIMENTACIÓ ININTERROMPUDA (SAI)

Els sistemes d'alimentació ininterrompuda han de tenir les característiques adequades als equips a què es connectaran.

No té cap sentit connectar un SAI de gamma alta a un ordinador personal d'un usuari domèstic, ni un SAI de gamma baixa en una habitació de servidors d'un centre de dades.

A més, un model de SAI té una capacitat limitada. Això vol dir que el nombre d'equips que s'hi connectin ha de consumir una potència inferior a la potència màxima que suporta el SAI.

Un altre aspecte important és la relació entre la càrrega i l'autonomia, factors determinants en l'elecció d'un model concret. També cal tenir en compte la capacitat d'un SAI i la influència del nombre d'equips que s'hi poden connectar (càrrega). Caldrà calcular la potència que consumeixen els equips per escollir el model de SAI més adient.

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

1. Alteracions del subministrament elèctric

Els ordinadors necessiten que el seu aliment, l'electricitat, els arribi de manera constant i de la manera més pura possible. Una pèrdua sobtada de corrent elèctric pot malmetre el maquinari i produir pèrdues de dades amb una importància vital.

*A banda de les **apagades elèctriques**, el subministrament elèctric pot presentar altres problemes que poden fer malbé els equipaments informàtics:*

- ***Sobretensions:** quan el voltatge de la línia és més gran del que hauria de ser.*
- ***Baixades de tensió:** quan el voltatge de la línia és més petit del que hauria de ser.*
- ***Variació de la freqüència:** quan la freqüència del senyal elèctric és diferent de la que hauria de ser (50 Hz a Europa).*

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

2. Sobreensions

Els dispositius elèctrics i electrònics, com els ordinadors, estan dissenyats per treballar amb un **voltatge o tensió màxima** concrets. Si un dispositiu rep un voltatge superior al màxim permès, efecte conegut com a **sobreensió**, pot patir danys i desperfectes que n'impedeixin el funcionament correcte.

Per exemple, si tenim un díode electroluminescent (LED) que emet llum quan rep una tensió d'1,35 volts i suporta un màxim d'1,6 volts i el connectem directament a dues piles d'1,5 volts, el díode rebrà 3 volts de tensió elèctrica i es fondrà a l'instant. D'una manera similar, altres aparells elèctrics poden deixar de funcionar o fins i tot cremar-se si reben una **sobreensió**.

Hi ha dos tipus de sobreensions: les **permanents** i les **transitòries**, depenent de la durada que tinguin. Les més habituals són les sobreensions transitòries, que duren pocs nanosegons.

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

Les sobretensions transitòries són causades principalment per:

- Apagades elèctriques
- Llamps
- Curtcircuits
- Mals funcionaments causats per la companyia elèctrica
- Alteracions del flux de corrent de la línia elèctrica produïdes per altres equipaments (grans motors, aires condicionats...)

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

Un **descarregador de sobretensió** (surge suppressor) és un aparell que protegeix els dispositius elèctrics de les sobretensions transitòries. Hi ha descarregadors de sobretensió amb múltiples preses de corrent que permeten connectar diversos dispositius alhora.

No tots els endolls amb múltiples preses de corrent porten un descarregador de sobretensió. Si no indiquen aquest tipus de protecció simplement serveixen per a subministrar el corrent elèctric.

Els descarregadors de sobretensió ofereixen una primera mesura de protecció elèctrica a un preu econòmic i, per aquest motiu, es connecten sovint a equips d'usuaris com ordinadors personals, impressores, monitors, etc. Per protegir amb més robustesa equips informàtics d'importància cabdal s'utilitzen **sistemes d'alimentació ininterrompuda** que combinen diverses mesures de protecció elèctrica.

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

Baixades de tensió

Quan un gran motor s'engega consumeix una gran quantitat de corrent elèctric de cop. Això fa que es redueixi el flux elèctric per a altres dispositius connectats a la mateixa línia. Llavors es produeixen baixades de tensió momentànies.

Per a l'equipament informàtic, les baixades de tensió són menys serioses que les sobretensions. La majoria l'equipament elèctric tolera fluctuacions de corrent més aviat grans.

Els **reguladors de voltatge** són circuits electrònics que mantenen un nivell de voltatge en una línia elèctrica. Eliminen sobretensions però també **baixades de tensió**. Un **mòdul regulador de voltatge** (VRM, voltage regulator module) és un regulador de voltatge contingut en una unitat reemplaçable.

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

3. Components d'un SAI

Avui en dia **aturar** temporalment un o més **servidors** informàtics pot comportar **fortes pèrdues econòmiques** en alguns casos. Si l'aturada és causada per una **apagada elèctrica**, també hi ha el risc que parts del maquinari s'**espatllin**. En aquest darrer cas, el temps per tornar a posar a punt les màquines afectades s'incrementa encara més, ja que s'han d'aconseguir peces noves i canviar-ne les malmeses.

*Una solució al possible tall sobtat de corrent elèctric és utilitzar un o més sistemes d'alimentació ininterrompuda, coneguts com a **SAI** (**UPS** en anglès, uninterruptible power supply). Aquests equips assegurin una alimentació elèctrica continuada, encara que es produixin talls de llum. A més, els SAI garanteixen una bona qualitat del corrent elèctric que arriba als aparells.*

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

Els SAI disposen d'**una o més bateries** per subministrar l'electricitat als equips connectats. Generalment, també tenen **altres elements** que protegeixen de les alteracions del subministrament elèctric (sobretensions, baixades de tensió, soroll de línia, etc).

Actualment, hi ha una **gran varietat de models** i fabricants de SAI, des de petits, senzills i econòmics, per a ordinadors personals; fins a grans, complexos i costosos per a **centres de processament de dades** (CPD). Depenent del fabricant i del model del SAI, s'obtindrà **més o menys protecció** de les alteracions del subministrament elèctric i/o una **autonomia** més gran o més petita.

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

4. Autonomia d'un SAI

En cas d'un tall de corrent, els SAI ofereixen un temps limitat de subministrament elèctric que pot oscil·lar entre els pocs minuts i algunes hores, depenent de la tecnologia del SAI i de la quantitat i de la mida de les bateries.

*Aquest temps extra serveix normalment per aturar les màquines d'una manera ordenada o per posar en marxa una font d'alimentació alternativa, com pot ser un **grup electrogen**.*

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

5. Parts d'un SAI

Per tal de poder verificar el funcionament dels sistemes d'alimentació ininterrompuda, cal conèixer les diverses parts i els components que tenen aquests aparells.

Indicadors d'estat

Els indicadors d'estat d'un SAI en permeten verificar ràpidament el funcionament. En la següent imatge es mostren alguns dels indicadors més comuns d'un SAI.

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

Indicadors d'estat d'un SAI

- **De línia (online):** quan està encès indica que la unitat funciona amb corrent de la línia elèctrica. Per a un SAI de tipus standby, aquest és el mode normal d'operació.
- **De bateria (on battery):** si està encès indica que el SAI funciona amb l'energia de la bateria.
- **Sobrecàrrega (overload):** aquest indicador s'il·luminarà quan es connectin més equips dels que el SAI pot gestionar. Així, doncs, caldrà disminuir el nombre d'equips connectats o augmentar la capacitat del SAI, si és possible.
- **Substituir bateria (replace battery):** el SAI comprova periòdicament l'estat de la bateria. Quan la bateria estigui malament, el LED s'il·luminarà i indicarà que cal substituir-la.

Alguns SAI disposen d'indicadors auditius per avisar de possibles problemes. El nombre de sons que es produeixen poden significar coses diverses. Consultant el manual en podrem esbrinar el significat exacte.

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

Programes de control i monitoratge

Els indicadors lluminosos d'estat donen la informació mínima necessària per detectar si tot va bé o si hi ha algun problema. Per obtenir informació extensa molts SAI porten programes que mostren encara més dades en format gràfic mitjançant quadres de diàleg.

Per obtenir tota aquesta informació cal instal·lar en un ordinador el programa que subministra el fabricant i connectar aquest ordinador al SAI amb un cable. Els SAI més antics tenien ports en sèrie, però actualment s'utilitza més sovint el port USB.

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

El programari de control d'un SAI varia en funció del model i del fabricant però, en general, inclou funcionalitat en les categories següents:

- **Estat:** es mostra informació de l'estat actual com la càrrega actual de la bateria, la càrrega d'equips connectats, les condicions ambientals (humitat, temperatura, etc.) i les característiques elèctriques del corrent d'entrada i de sortida.
- **Registre (logging):** es manté un diari dels esdeveniments que es van donant: interrupcions de corrent, comprovacions rutinàries, etc.
- **Diagnòstic:** permet fer diverses comprovacions al SAI o planificar-les per a més endavant.
- **Alarmes PC:** permet configurar que s'enviïn notificacions a l'ordinador al qual està connectat el SAI quan apareguin problemes o que es canviï al mode en bateria.
- **Apagada automàtica:** en cas de fallada elèctrica, el SAI pot enviar les instruccions adients perquè l'ordinador es tanqui d'una manera segura, que tanqui els programes oberts i també el sistema operatiu.

[Apli](#)

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

6. Tipus de SAI

Els SAI es classifiquen en dos tipus: els que treballen de manera continuada (**online**) i els que treballen només quan detecten un tall de corrent (**offline**).

- **SAI standby (offline)**: Són els més econòmics, recomanats per els **equips de casa**. No estableixen la corrent i només generen la tensió de sortida quan es produeix un tall en el subministrament elèctric. El problema que tenen és el **temps de transferència o latència** que és el temps des que se'n va la llum fins que s'alimenta l'ordinador amb la bateria passa un interval de temps breu, de l'ordre d'una fracció de segon, que podria ser massa temps segons en quins equips, tot i que no és l'habitual.

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI). TIPUS DE SAI

- **SAI Inline o Line Interactive (offline):** Equips de **gama mitja-alta** que estableixen la corrent incorporant un estabilitzador de sortida (AVR) i reduint el **temps de transferència o latència** anterior, però no evitant-lo completament. Només generen la tensió de sortida quan es produeix un tall en el subministrament elèctric. Són adequats per ordinadors, centraletes telefòniques i equips servidors de petites i mitjanes empreses (PYME)
- **SAI OnLine o de Doble Conversió (online):** Equips de **gama alta**, pensats per protegir sistemes crítics. Aquests equips generen sempre la tensió de sortida nova, independentment de l'entrada. D'aquesta forma, quan hi ha un tall en el subministrament elèctric, **no hi ha temps de transferència o latència**.

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

7. Potència necessària

Hi ha diversos factors que cal tenir en compte abans d'adquirir i d'instal·lar un SAI: *la mida que té, el tipus de SAI, la càrrega que suporta, el grau de protecció contra les alteracions del subministrament elèctric, etc.*

Depenent del cas, escollireu un model o un altre tenint en compte el nombre i el tipus d'ordinadors que vulgueu protegir.

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

Tres de les característiques més rellevants d'un SAI són la **càrrega**, l'**autonomia** i la **capacitat**, conceptes que estan relacionats entre ells.

*La **càrrega** d'un SAI és el conjunt d'equips que té connectats. L'**autonomia** d'un SAI és la quantitat de temps que podrà subministrar energia de la bateria a una càrrega concreta.*

*La **capacitat** d'un SAI és la potència màxima que podrà subministrar a la seva càrrega.*

Quan mesurem la capacitat d'un SAI ens podem trobar amb dues mesures. La **potència real** o la **potència aparent**.

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

La **potència real** és la que es mesura en Watts (W) i la **potencia aparent** en VoltAmpers (VA).

La diferència és que la **real** ens dona la potència que consumeix un aparell i la **aparent** és la potència real multiplicada per un factor per tenir en compte el **pic màxim** de potència a la que podria arribar un equip. Aquest factor acostuma a ser 1,4 tot i que ens podrem trobar 1,33 o 1,6.

S'ha de tenir en compte que quan calculem la capacitat necessària d'un SAI (normalment ve expressada en VA) sempre hem de calcular una capacitat un **60% o 70%** superior.

.

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

Per exemple:

si volem connectar a un SAI 2 PCs i 2 Monitors que consumeixen un total de 200 W (potència real), el nostre SAI haurà de subministrar:

$$200 * 1,4 = 280 \text{ VA.}$$

Però com que hem de tenir en compte que aquesta potència no pot superar el 70% de la potència total del SAI (VA), necessitarem un SAI de com a mínim 400 VA ($400 \text{ VA} * 70\% = 280 \text{ VA}$).

3.7. SISTEMES D'ALIMENTACIÓ ININTERRUMPUDA (SAI)

Hi han diversos mètodes per calcular el consum en W dels nostres equips i d'aquesta forma fer una estimació:

- Mitjançant un mesurador de potència o mitjançant una **pinça amperimètrica** que mesura el **corrent subministrat** per els equips connectats, d'aquesta manera multiplicant per la tensió nominal (230 V a Espanya), podrem obtenir el consum mig aproximat.
- Coneixent el **consum mig** (W) subministrat en la característiques del fabricant.
- Mitjançant un model aproximat d'estimació de consum, prenent com referència estimacions prèvies.

Per exemple podem veure estimacions de consums en la web d'etiquetat d'eficiència energètica Energy Star.

3.8. CÒPIES DE SEGURETAT

Per qualsevol *incident* (malware, accés no autoritzat, errors de hardware o per accident o descuit) la informació continguda en el nostre equip pot resultar malmesa o inclús desaparèixer. Les còpies de seguretat o backup, són **rèpliques de dades que ens permeten recuperar la informació original** en cas de ser necessari.

Correspon a cada usuari o a l'administrador del sistema determinar quines són les dades que per la seva importància seran guardades en la còpia de seguretat.

Aquestes còpies es poden emmagatzemar en suports extractables (C/DVD, pendrive, cintes de backup, etc), en altres directoris o particions de dades de la nostra pròpia màquina, en unitat compartides d'altres equips o en discs de xarxa, en servidors remots, etc.

3.8. CÒPIES DE SEURETAT

Depenent del tipus d'informació que continguin aquestes còpies de seguretat, hauran d'estar xifrades i comprimides en un sol arxiu facilitant la seva confidencialitat, manteniment i distribució.

Existeixen multitud d'eines, algunes preinstal·lades en els propis sistemes operatius, altres com aplicacions específiques. Algunes de les opcions que s'han d'analitzar són:

- **Compressió:** és el millor mètode per disminuir l'espai d'emmagatzematge necessari i d'aquesta forma reduir el cost.
- **Duplicació:** còpies de seguretat duplicades en un segon suport d'emmagatzematge. Això pot fer-se per canviar de lloc les còpies, per optimitzar velocitats de restauració, o inclús per disposar d'una segona còpia segura en un lloc o suport diferents.

3.8. CÒPIES DE SEGURETAT

- **Xifrat:** l'alta capacitat dels suports d'emmagatzematge desmuntables implica un risc de que es perdi o ser robat. Si es xifra la informació d'aquest suports es pot reduir el problema tot i que apareixen nous inconvenients (Tot i que amb informació confidencial és recomanable utilitzar aquesta opció).
 - Primer, xifrar és un procés que consumeix molta CPU i pot baixar la velocitat de còpia.
 - Segon, un cop xifrades les dades, la compressió és menys eficaç.
- **Nom de l'arxiu:** s'acostuma a incloure el tipus de còpia i la data (en el cas de còpies totals) o dates (en el cas de diferencials i incrementals) de les dades.

3.8. CÒPIES DE SEGURETAT

Models d'emmagatzematge de dades

Les dades de la còpia han de ser emmagatzemats d'alguna forma i probablement hagin de ser organitzats amb algun criteri. Per fer això podem utilitzar un simple full de paper amb una llista de les cintes utilitzades en les còpies i les dates en la que van estar fetes, fins un sofisticat programa amb una base de dades.

Un magatzem **desestructurat** o conjunt de disquets, CD/DVD, memòries USB, discs durs externs o cintes de backup amb una mínima informació sobre què ha estat copiat i quan, és la forma més fàcil d'implementar però ofereix poques garanties de recuperació de dades. El més normal és treballar amb magatzems **estructurats**, que segons el nombre d'arxius a guardar a l'hora de realitzar la còpia de seguretat es poden distingir en tres tipus:

3.8. CÒPIES DE SEGURETAT

Models d'emmagatzematge de dades

Segons el nombre d'arxius a guardar a l'hora de realitzar la còpia de seguretat es poden distingir en tres tipus:

- **Completa, total o íntegra:** és una còpia de seguretat total de tots els arxius i directoris seleccionats.
- **Incremental:** es fa una còpia de seguretat només dels arxius que hagin canviat des de la última còpia de seguretat realitzada (sigui del tipus que sigui). Té en compte els bits d'arxiu modificat.
- **Diferencial:** similar a la incremental però realitza una còpia de tots els arxius modificats des de la última còpia de seguretat total que s'hagi fet.

3.8. CÒPIES DE SEGURETAT

- **Incremental**

- *Pros*: En una còpia incremental, només es guardaran els **canvis** que s'hagin fet **des de la còpia anterior**, per tant el **volum** d'informació que es guardarà cada dia serà **menor** que el de la total i a més la còpia es realitza molt ràpidament.
- *Contres*: En una còpia incremental, davant d'un desastre, haurem de disposar de la còpia total (i última diferencial si en tenim) i de **totes** les incrementals que s'hagin realitzat des d'aquesta.

3.8. CÒPIES DE SEGURETAT

- **Diferencial**

- *Pros*: En el procés de restauració només necessitarem la còpia total i la **última** còpia diferencial.
- *Contres*: En cada còpia diferencial al guardar **tots els canvis des de la total**, el **volum** d'informació guardat serà **molt gran** i es trigarà més en realitzar la còpia.

3.8. CÒPIES DE SEGURETAT

Recomanacions sobre el tipus de còpia a realitzar

El tipus de còpia a realitzar dependrà del volum de dades a copiar i de la freqüència en que es modifiquin.

Si el **volum** de dades de la nostra còpia de seguretat **no és molt elevat** (menys de 4Gb), el més pràctic és realitzar **sempre còpies totals** ja que en cas de desastre, només hem de recuperar la última còpia.

Si el **volum** de dades de la nostra còpia és **molt elevat** (major de 50 Gb) però el volum de dades **que es modifiquen no és elevat** (pels voltants de 4 Gb), el més pràctic és realitzar una **primera còpia total** i posteriorment, realitzar sempre **còpies diferencials**.

3.8. CÒPIES DE SEGURETAT

Si el **volum** de dades de la nostra còpia és **molt elevat** (major de 50 Gb) però el volum de dades **que es modifiquen és també elevat**, les còpies diferencials ocupen molt espai i per tant serà fer una **primera còpia total** i després fer **sempre còpies incrementals** ja que són les que ocupen menys espai.

En grans companyies on les còpies de seguretat estan planificades s'utilitzen moltes vegades els sistemes mixtos. Per exemple:

- Tots els dies 1 de cada mes. a les 23:30 hores: **còpia total**.
- Tots els divendres a les 23:30 hores: **còpia diferencial** des de la còpia del dia 1.
- Tots els dies (excepte els divendres i el dia 1) a les 23 hores: **còpia incremental** des de la còpia del dia anterior.

3.8. CÒPIES DE SEGURETAT

D'aquesta forma ens assegurariem de disposar de còpia de seguretat diària. En cas de desastre hauríem de recuperar la còpia total, la última diferencial i totes les incrementals des de la última diferencial.

Per garantir aquesta disponibilitat de les dades en cas de desastre és recomanable distribuir les còpies en diverses localitzacions. Normalment es contracten empreses especialitzades que **transportin i custodiïn** duplicats de les còpies, o utilitzar **emmagatzematge remot**, o backup online o **en el núvol**.

3.8. CÒPIES DE SEGURETAT

Recuperació de dades

En el cas d'haver estat víctima d'un atac o haver patit algun accident o error de hardware ens podem trobar que hi ha certa informació que s'ha esborrat i ens preguntem, podem recuperar arxius esborrats definitivament del nostre sistema? La resposta és sí, però amb matisos.

Quan **menys** temps hagi transcorregut entre l'esborrat i la recuperació millor serà el resultat d'aquesta.

Normalment, quan esborrem informació d'un dispositiu, l'únic que fa el sistema es **desvincular** les posicions que ocupaven aquells arxius de la estructura de dades del Sistema Operatiu, de forma que queden disponibles per a nova informació, però realment **segueixen en el disc** tot i que no hi ha un accés des de el sistema operatiu. Mentre no s'escrigui informació de nou en aquestes posicions, la informació seguirà allí, i amb les eines adequades podríem recuperar-la.

3.8. CÒPIES DE SEGURETAT

En el cas d'haver estat víctima d'un atac o haver patit algun accident o error de hardware ens podem trobar que hi ha certa informació que s'ha esborrat i ens preguntem, podem recuperar arxius esborrats definitivament del nostre sistema? La resposta és sí, però amb matisos.

Quan **menys** temps hagi transcorregut entre l'esborrat i la recuperació millor serà el resultat d'aquesta.

Normalment, quan esborrem informació d'un dispositiu, l'únic que fa el sistema es **desvincular** les posicions que ocupaven aquells arxius de la estructura de dades del Sistema Operatiu, de forma que queden disponibles per a nova informació, però realment **segueixen en el disc** tot i que no hi ha un accés des de el sistema operatiu. Mentre no s'escrigui informació de nou en aquestes posicions, la informació seguirà allí, i amb les eines adequades podríem recuperar-la.

3.8. CÒPIES DE SEGURETAT

Per exemple en sistemes **Windows** podríem utilitzar entre d'altres l'aplicació [Recuva](#) o en sistemes **Linux** l'aplicació [Foremost](#).

Hi ha una altre aplicació multiplataforma per recuperar arxius, sobretot de dispositius extraïbles que és senzilla i molt eficaç [TestDisk](#). Podem instal·lar-la directament des de el repositori de Linux o per comandes.

```
$ sudo apt-get install testdisk testdisk-dbg
```

3.8. CÒPIES DE SEGURETAT

Mitjans d'emmagatzematge

Tenint en compte els **models d'emmagatzematge massiu** dels sistemes d'avui en dia trobem:

Més endavant, quan parlem de xarxes corporatives, veurem un exemple de com implementar un servidor NAS per diferents usuaris.

3.8. CÒPIES DE SEGURETAT

Còpies de seguretat en GNU/Linux

Per empaquetar arxius en Linux, s'acostuma a utilitzar la comanda “**tar**”. Tot i que podem utilitzar d'altres com *gzip*, *zip*, *bzip2*, *rar*.

Per crear l'arxiu seria:

```
tar -vcf nom_arxiu.tar nom_carpetes_a_empaquetar
```

Per desempaquetar l'arxiu seria:

```
tar -tvxf nom_arxiu.tar
```

3.8. CÒPIES DE SEGURETAT

Per programar la periodicitat de les còpies utilitzarem el **cron** i per modificar-lo, la comanda crontab

crontab [-e | -l | -r] [usuari]

El format que té el crontab és el següent:

a b c d e comanda_o_programa_a_executar

a = Minut (0-59)

b = Hora (0-23)

c = Dia del mes (1-31)

d = Mes (1-12)

e = Dia de la setmana (0-6) (0 Diumenge)

3.9. SEGURETAT FÍSICA

Centre de Processament de Dades (CPD)

Centre de processament de dades (CPD) és aquella ubicació on es concentren els recursos necessaris per al processament de la informació d'una organització.

També es coneix com a **centre de còmput** a Llatinoamèrica, o **centre de càlcul** a Espanya o centre de dades pel seu equivalent en anglès **data center**.

Aquests recursos consisteixen essencialment en unes dependències degudament condicionades, computadores i xarxes de comunicacions.

Un **CPD** és un edifici o sala de gran grandària utilitzada per a mantenir en ella una gran quantitat d'equipament electrònic. Acostumen a ser creats i mantinguts per grans organitzacions a fi de tenir accés a la informació necessària per a les seves operacions.

3.9. SEGURETAT FÍSICA. CPD

*Un **banc** pot tenir un data center amb el propòsit d'emmagatzemar totes les dades dels seus clients i les operacions que aquests realitzen sobre els seus comptes.*

Pràcticament totes les companyies que són mitjanes o grans tenen algun tipus de CPD, mentre que les més grans arriben a tenir varis.

Un dels **factors més importants** que motiven la creació d'un CPD a destacar seria el garantir la **continuitat del servei i la alta disponibilitat** a clients, empleats, ciutadans, proveïdors i empreses col·laboradores, doncs en aquests àmbits és molt important la **protecció física** dels equips informàtics o de comunicacions implicats, així com servidors de bases de dades que puguin contenir informació crítica.

3.9. SEGURETAT FÍSICA

Els requisits serien:

- **Disponibilitat i monitorització "24x7x365"**: Les 24 hores del dia, els sets dies de la setmana, els 365 dies de l'any.
- **Alta disponibilitat (5 nous)**: Un 99,999% de disponibilitat
- **Seguretat, redundància i diversificació**: emmagatzematge exterior de dades, preses d'alimentació elèctrica totalment independents, balanceig de càrrega, SAI, control d'accés físic,...
- **Control ambiental/prevenció d'incendis**: qualitat de l'aire, temperatura, humitat, inundacions, control del foc,

3.9. SEGURETAT FÍSICA

Normalment els grans servidors d'un CPD s'acostumen a concentrar en una sala denominada sala freda, nevera o peixera i que acostuma a estar em una temperatura baixa (entre 21 i 23 °C). Segons normes internacionals, la temperatura exacta hauria de ser de 22,3 °C, recomanada entre 15 i 23 °C, i humitat relativa entre 40% i 60%.

Tot i que són difícils de predir amb exactitud, les condicions atmosfèriques adverses severes es localitzen tan física com temporalment en certes parts del món i **la probabilitat de que succeeixin està documentada.**

3.9. SEGURETAT FÍSICA

Per tan quan escollim la ubicació i construcció d'un CPD hauríem de tenir els següents aspectes en compte (com ja s'ha vist amb anterioritat):

- Incendis
- Sistema d'aire condicionat
- Inundacions
- Terratrèmols
- Rajos i interferències electromagnètiques

3.9. SEGURETAT FÍSICA

Control d'accés físic

La utilització de **credencials d'identificació** és un dels punts més importants del sistema de seguretat físic, per poder efectuar un control eficaç de l'ingrés i sortida del personal als diferents sectors de l'empresa.

El control de l'accés físic no només requereix la capacitat d'identificació, sinó d'associar aquesta a l'**obertura o tancament de portes**, permetre o denegar l'accés basat en **restriccions de temps**, àrea o sector dins d'una empresa o institució.

3.9. SEGURETAT FÍSICA

Vist això, podríem dir que a les persones se les pot identificar per:

- **Alguna cosa que es posseeix:** una clau, una targeta d'identificació o targeta intel·ligent (SmartCard)
- **Alguna cosa que es sap:** un número d'identificació personal (PIN) o password que és sol·licitarà per poder ingressar.
- **Alguna cosa que s'és** (senyals d'identitat: mans, ulls, empremtes, veu) o **es sap fer** (firma escrita). És el principi que utilitza la biometria, és el mètode més segur ja que és molt difícil de falsificar.

Aquests identificadors **es poden combinar** augmentant la seguretat.

3.9. SEGURETAT FÍSICA

Cadascun d'aquests identificadors associats a cada persona o usuari s'emmagatzemen una base de dades que ha de controlar un servei de vigilància per el seu posterior seguiment si fos necessari.

El **problema** principal en aquest cas és que aquest sigui **subornat**. I les **targetes** poden ser **robades, copiades**, etc. Els **nombres secrets** poden arribar a mans d'**usuaris no autoritzats** , permetent entrar a qualsevol persona que la tingui.

La biometria ajuda a millorar el nivell de seguretat.

3.9. SEGURETAT FÍSICA

una altre solució molt utilitzada en les sales d'equipament informàtic és la de disposar d'un **armari o rack sota clau**. Aquest no és més que un **bastidor** destinat a allotjar equipament electrònic, informàtic i de comunicacions.

Les seves mesures estan **normalitzades** perquè sigui compatible amb l'equipament de qualsevol fabricant:

- Estructura metàl·lica amb una amplada de **19 polsades**.
- Dues guies verticals amb forats a intervals regulars anomenats **unitats de rack (U)** agrupats de tres en tres.
- Verticalment dividits en regions de **1,75 polsades d'altura = 1 U**, amb tres forats en cada guia.
- **Alçada (4 - 46 U) no està normalitzada**, donant així més flexibilitat a l'equipament.

3.9. SEGURETAT FÍSICA

- La **profunditat** del bastidor (600, 800, 1000 mm) **tampoc està normalitzada**.

L'estructura pot constar de safates horitzontals on pot recolzar-se l'equipament no normalitzat com un monitor, PC, teclat o ratolí.

Els dispositius que si solen allotjar són:

- Servidors.
- [Patch Panels](#) (que centralitzen el cablejat de l'armari).
- Sistemes d'audio i video.
- SAIs (UPS).
- Switches.
- Routers.
- Tallafocs.

3.9. SEGURETAT FÍSICA

Sistemes Biomètrics

La **biometria** és l'estudi de **mètodes automàtics per al reconeixement únic d'humans** basats en un o més trets conductuals o físics intrínsecs.

La "**biometria informàtica**" és l'aplicació de tècniques matemàtiques i estadístiques sobre els trets físics o de conducta d'un individu, per “**verificar**” identitats o per “**identificar**” individus.

En les tecnologies de la informació (TU), l'autenticació biomètrica es refereix a les tecnologies per mesurar i analitzar les **característiques físiques i del comportament** humanes amb propòsit d'autenticació.

Les **característiques biomètriques** d'una persona **són intransferibles** a una altre, per el que fa que aquests sistemes siguin **molt segurs**.

3.9. SEGURETAT FÍSICA

Alguns dels sistemes biomètrics més comuns són:

- **Empremta digital:** Es basa en el principi que no existeixen dues d'iguals. És un mètode d'identificació bastant fiable i uns dels més utilitzats per la seva **baixa relació qualitat/preu**.
- **Verificació de veu:** la dicció d'una o més frases gravades i en l'accés és compara la veu (entonació, diftongs, agudesa, etc.). Té un problema important, és **sensible a factors externs** com el soroll, l'estat d'ànim i enfermetats de la persona, envelliment, etc. Per tant no és un mecanisme molt adoptat.

3.9. SEGURETAT FÍSICA

- **Verificació de patrons oculars:** basat en els patrons de l'iris o la retina i fins al moment **són els considerats més efectius**.
- **Verificació automàtica de signatures (VAS):** Tot i que es detecta en un gran nombre si una firma és autèntica o no, en molts casos no és així.

Aquests sistemes el que fan és utilitzar també les emissions acústiques, prenent dades del procés dinàmic de signar o d'escriure i tota aquesta

seqüència constitueix un patró **únic en cada individu** i és més difícil de falsificar que la simple signatura.

- **Reconeixement facial:** El rostre de la persona és una característica física que permet la identificació de la persona de manera única i estable.

3.9. SEGURETAT FÍSICA

Existeixen equips que capturen el patró 2D (projecció en el plànol) i equips que capturen el patró 3D (descripció volumètrica del rostre).

El **desavantatge dels equips 2D** és que el sistema no distingeix si el que està capturant és realment un rostre o una fotografia d'un rostre, per la qual cosa no ofereixen un nivell de seguretat suficient en la majoria d'aplicacions de control d'accés.

Els equips 3D ofereixen una seguretat molt més elevada ja que necessiten un rostre real (no una fotografia) per identificar l'usuari. Per aquesta raó en aplicacions de control d'accés i control de presència és **aconsellable usar equips de reconeixement facial 3D**.

3.9. SEGURETAT FÍSICA

Circuit Tancat de Televisió (CTTV)

S'anomena **protecció electrònica** a la detecció de robatoris, intrusió, assalt i incendis mitjançant la utilització de **sensors connectats a centrals d'alarmes**.

Permeten el control de tot el que succeïx en la planta segons el captat per unes càmeres estratègicament col·locades.

En l'actualitat unes de les càmeres més utilitzades, per el seu baix cost i bones prestacions són les **càmeres IP** (transmeten les seves imatges a través

de xarxes IP com xarxes **LAN**, **WAN** o **WLAN**). Aquestes càmeres permeten a l'usuari tenir la càmera en una localització i veure el vídeo en temps

real des de un altre lloc a través d'Internet o xarxa local.

3.9. SEGURETAT FÍSICA

Data Centers

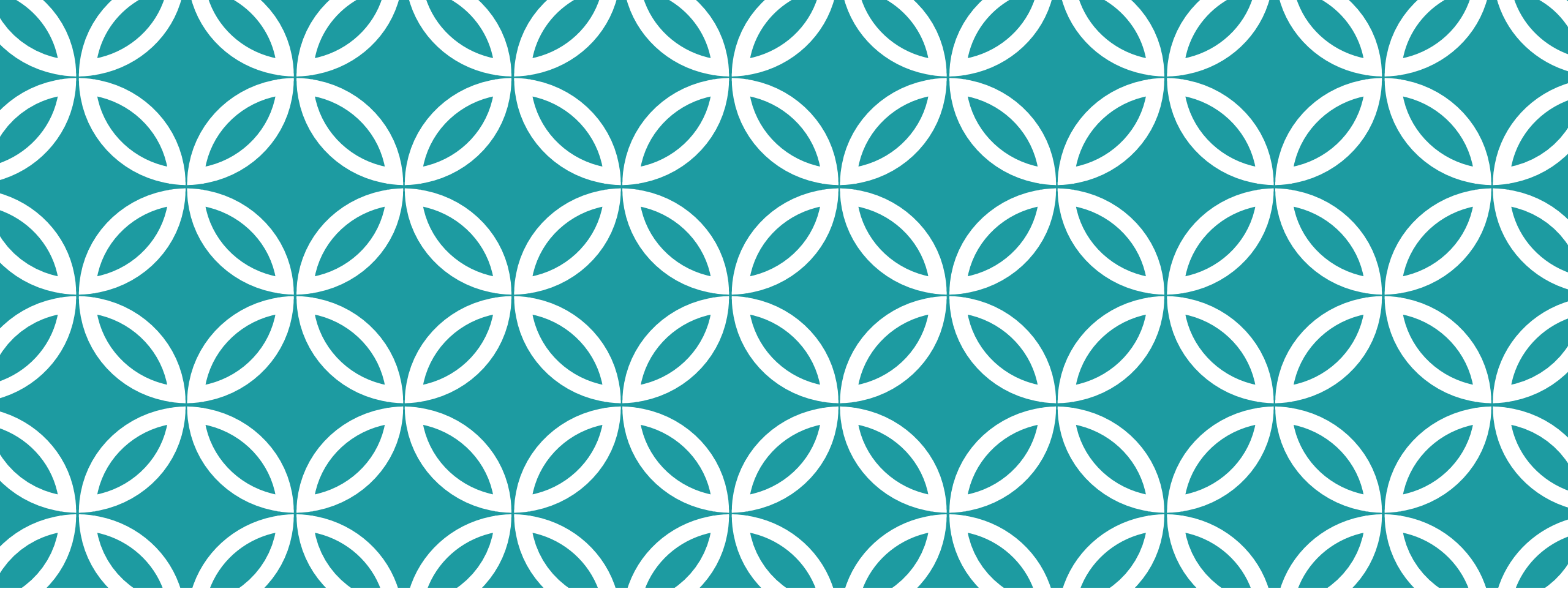
Swiss Fort Knox

Lulea Data Center

Nautilus Data Centers

Amazon Data Centers

Google Data Centers



4. SEGURETAT LÒGICA



4. SEGURETAT LÒGICA

La **seguretat lògica** consisteix en l'aplicació de **barreres** i **procediments** que **resguarden l'accés a les dades** i que només es permeti accedir a elles a les persones autoritzades a fer-ho.

Per tant, la seguretat lògica es sustenta en el **control d'accés** als recursos informàtics (**identificació, autenticació i autorització**) i en la efectiva administració i **gestió dels permisos**.

4. SEGURETAT LÒGICA

1. Control d'accés lògic

El control d'accés lògic és la **principal mesura de defensa** per la majoria de sistemes i d'aquesta forma impedir l'accés a aquests per part de persones no autoritzades.

Per **controlar aquest accés** s'utilitzen els següents processos:

- **Identificació:** quan l'usuari **es dona a conèixer** en el sistema.
- **Autenticació:** La **verificació**, mitjançant les proves pertinents, que és realitza d'aquesta identificació.
- Finalment, l'**autorització** és el pas que determina què pot fer l'usuari al sistema.

4. SEGURETAT LÒGICA

Single login o *sincronització de passwords*, és com es denomina el fet que des de el punt de vista de la eficiència, els usuaris siguin **identificats i autenticats només una vegada**, i a partir d'aquí accedir a totes les aplicacions, dades i recursos que el seu perfil li permeti.

Per implementar el **single login** una de les formes seria utilitzant un **servidor d'autenticacions**. Aquest s'encarrega, un cop els usuaris s'han identificat sobre ell, d'autenticar-los sobre la resta d'equips als que l'usuari pugui accedir.

Uns exemples d'aquest tipus de servidors els tindríem en els servidors **LDAP** (GNU/Linux) i **Active Directory** (Windows Server).

4. SEGURETAT LÒGICA

Qualsevol sistema amb un control d'accés per contrasenya, acostuma a ser un punt crític en la seguretat i per això acostumen a rebre diferents atacs, els més comuns són:

- **Atac de força bruta:** S'intenta recuperar una clau **provant totes les combinacions possibles** fins trobar aquella que permeti l'accés. Quan més curta, més senzilla de trobar provant combinacions.
- **Atac de diccionari:** Prova de trobar la clau **provant totes les paraules d'un diccionari o conjunt de paraules comuns**. Ja que la gent al posar una clau acostuma a fer-ho amb alguna paraula existent en el seu idioma (o en algun altre) perquè és més fàcil de recordar (cosa que no es gens recomanable).

4. SEGURETAT LÒGICA

Una forma "senzilla" per protegir un sistema amb contrasenya de possibles atacs de força bruta o de diccionari, és establir un **nombre màxim d'intents**.

Així si es sobrepassa es bloqueja el sistema.

4. SEGURETAT LÒGICA

Polítiques de contrasenyes

Tenint clar que com hem anat recordant no hi ha res 100% segur, perquè una contrassenya sigui segura hauríem de seguir les següents recomanacions:

- **Longitud mínima:** sabem que cada caràcter que afegim a una contrassenya augmenta exponencialment el grau de protecció d'aquesta. Per tant la longitud mínima hauria de ser de **8 caràcters**, tot i que l'aconsellable seria **14**.
- **Combinació de caràcters** (lletres majúscules i minúscules, nombres i símbols especials): quan més variació de caràcters fem, més difícil serà endevinar-la.

4. SEGURETAT LÒGICA

Per un atac de **força bruta**, si utilitzem una contrasenya de 5 caràcters en minúscula per idioma espanyol que té 27 caràcters diferents, hauria de provar: $27^5 = 14\,348\,907$ conuinacions.

Si utilitzéssim majúscules i minúscules les combinacions augmentarien de manera que seria $(27 \times 2)^5 = 52^5 = 380\,204\,032$ conuinacions.

4. SEGURETAT LÒGICA

Per evitar utilitzar contrasenyes fàcils d'endevinar hauríem de seguir les següents **recomanacions**:

- No incloure seqüències ni caràcters repetits ("12345678", "2222222", "abcdefg")
- No utilitzar el nom d'inici de sessió.
- No utilitzar paraules de diccionari de cap idioma.
- Utilitzar varies contrasenyes per a diferents entorns.
- Evitar la opció de contrasenya en blanc.
- No desvetllar la contrasenya a ningú i no escriure-la en equips que no controlen.
- Canviar les contrasenyes amb regularitat.

4. SEGURETAT LÒGICA

Els diferents **nivells de control d'accés** per contrasenyes serien:

- **1er. nivell:** contrasenya d'arrancada i de la propia configuració de la **BIOS**.
- **2on. nivell:** control mitjançant contrasenya dels **gestors d'arrencada** (per exemple: grub).
- **3er. nivell:** accés mitjançant usuari i contrasenya per part dels **sistemes operatius**.
- **4art. nivell:** contrasenya i xifrat d'accés a **dades i aplicacions** (arxius ofimàtics, comprimits, llocs web, etc..).

4. SEGURETAT LÒGICA

Control d'accés en la BIOS i gestor d'arrancada

La **BIOS** (Basic Input/Output System) és el nivell més baix de software que configura o manipula el Hardware d'un ordinador de forma que cada vegada que iniciem l'ordinador aquest s'encarrega de reconèixer tot el Hardware que conté l'ordinador i controlar a l'estat dels mateixos.

Com en la BIOS podem establir quin Hardware utilitzar, l'ordre d'arrancada, etc. hem de protegir-la de forma que només un Administrador o usuari responsable pugui modificar aquests valors.

4. SEGURETAT LÒGICA

Segon el model de BIOS podem tenir diverses opcions, entre elles:

- **Seguretat del sistema** (system): en cada arrancada de la màquina ens demanarà introduir una contrassenya, si no es correcte el sistema no arrancarà.
- **Seguretat de configuració de la BIOS** (setup): aquí s'acostuma a distingir entre dos rols:
 - *Usuari* (només lectura)
 - *Administrador* (lectura/modificacions)

4. SEGURETAT LÒGICA

Control d'accés en el sistema operatiu

Hi han **sistemes d'accés** al sistema operatiu molt segurs com accés per empremta dactilar, però **el més utilitzat** segueix sent a través de **contrasenya associada a una compte d'usuari**.

Hi han sistemes per accedir als SO **sense control de contrasenya**, entre ells els d'arrancar amb una **distribució Live** per poder recuperar o conèixer les contrasenyes de qualsevol usuari, així com esborrar-les o modificar-les.

Com a recomanació, podem utilitzar aquestes eines per **auditar** els nostres sistemes i **comprovar la fortalesa** de les nostres contrasenyes, ja que si les fem bé serà molt difícil recuperar-les amb aquestes eines.

4. SEGURETAT LÒGICA

Política d'usuaris i grups

La **definició de comptes** d'usuaris i la seva assignació de rols, perfils, grups, com els privilegis sobre els objectes del sistema, etc. són aspectes fonamentals de la seguretat i una de les **tasques principals de l'administrador** de sistemes.

4. SEGURETAT LÒGICA

Aquest procés comporta generalment quatre punts:

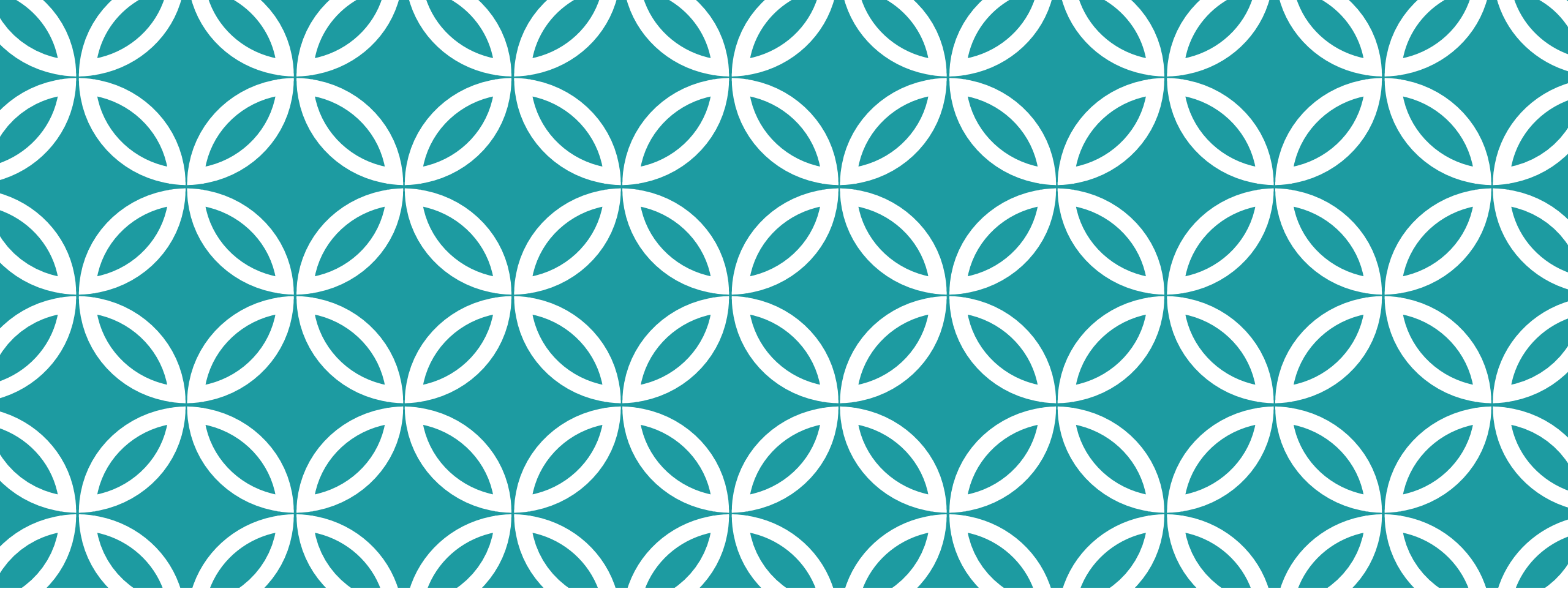
- **Definició de llocs:** Separació de funcions possibles depenent dels diferents llocs de treball.
- **Determinació de la sensibilitat del lloc:** determinar si una funció **requereix permisos crítics** que li permetin alterar processos, visualitzar informació confidencial, etc...
- **El·lecció de la persona para cada lloc:** requereix considerar els **requeriments d'experiència i coneixements** tècnics necessaris per a cada lloc.
- **Fomació inicial i continua dels usuaris:** han de conèixer les diferents **pautes de la organització**, la seva responsabilitat en quan a la seguretat informàtica i el que s'espera d'ells. Ha d'estar orientada a **incrementar la consciència** de la necessitat de protegir els recursos informàtics.

4. SEGURETAT LÒGICA

La **definició dels permís d'accés** requereix determinar **quin serà el nivell de seguretat necessari** sobre les dades, per el que és imprescindible **classificar la informació, determinant el risc** que produiria una eventual exposició de la mateixa a usuaris no autoritzats.

Per començar la implementació es convenient començar definint les mesures de seguretat sobre la **informació més sensible o les aplicacions més crítiques** i avançar d'acord a un **ordre de prioritats descendents**.

Un cop establert per les dades, s'hauran d'establir les mesures de seguretat per a cadascun dels nivells.



5. CRIPTOGRAFIA

5. CRIPTOGRAFIA

La **criptografia** (del grec "*kryptos*" - amagat, secret - i "*graphin*" - escriptura. Per tant seria "**escriptura oculta**") és l'estudi de formes de convertir informació des de la seva forma original cap a un codi incomprensible, de forma que sigui incomprensible pels que no coneguin aquesta tècnica.

Quan parlem d'aquesta àrea de coneixement com a ciència, hauríem de parlar de criptologia que engloba la **criptografia** i el **criptoanàlisis** (estudia els mètodes utilitzats per trencar texts xifrats amb l'objectiu de recuperar la informació original en absència de claus).

5. CRIPTOGRAFIA

els mètodes utilitzats per trencar texts xifrats amb l'objectiu de recuperar la informació original en absència de claus).

La criptografia moderna utilitza les disciplines de les matemàtiques, informàtica i telemàtica.

En la terminologia de criptografia, trobem els següents aspectes:

- La **informació original** que ha de protegir-se i que es denomina text en clar o **text pla**.
- El **xifrat** és el procés de convertir el text pla en un text il·legible, anomenat **text xifrat** o **criptograma**.

5. CRIPTOGRAFIA

- Algorismes de xifrat:
 - De **xifrat en bloc**: divideix el text origen en blocs de bits d'una mida fixa i els xifren de forma independent.
 - De **xifrat de flux**: el xifrat és realitza bit a bit, byte a byte o caràcter a caràcter.
- Les dues tècniques més senzilles de xifrat, en la criptografia clàssica, són:
 - La **substitució**: suposa el canvi de significat dels elements bàsics del missatge, les lletres, els dígitos o els símbols.
 - La **transposició**: suposa una reordenació dels mateixos, però els elements bàsics no es modifiquen en sí mateixos.
- El desxifrat: és el procés invers, recupera el text pla a partir del criptograma i la clau.

5. CRIPTOGRAFIA

Algorismes de Xifrat

La història de la criptografia es molt antiga. Ja les primeres civilitzacions l'utilitzaven per xifrar els missatges durant les campanyes militars, així si interceptaven el missatger, eren incapaços de descobrir el missatge. Un dels mes coneguts és el mètode **Cèsar**, anomenat així perquè se li atribueix a Juli Cèsar, que utilitzava durant les seves campanyes.

Era un sistema simple però efectiu, simplement desplaça tres lletres de l'abecedari per fer la substitució de les originals (imatge al peu del document).

5. CRIPTOGRAFIA

Exemple: En GNU/Linux podem utilitzar la comanda `tr` per realitzar xifratge de substitució com el Cèsar:

Creem un fitxer (*Document.txt*) amb un text després executem

```
cat Document.txt | tr [a-z] [d-zabc] | tr [A-Z] [D-ZABC] >  
document_cesar.txt
```

Veurem que ens ha creat el *document_cesar.txt* on apareix la informació del fitxer *Document.txt* xifrada segons el sistema Cèsar.

5. CRIPTOGRAFIA

Existeixen dos grans grups d'algorismes de xifrat:

- **Simètrics o de clau simètrica o privada:** els algorismes que utilitzen una única clau per xifrar la informació i la mateixa per desxifrar-la.
- **Asimètrics o de clau asimètrica o pública:** els que utilitzen una clau pública per xifrar el missatge i una clau privada per desxifrar-lo. Aquest és la base de les tècniques de xifrat modernes.

Segons el **principi de Kerckhoffs**, la fortalesa d'un sistema o algorisme de xifrat ha de recaure en la clau i no en l'algorisme.

5. CRIPTOGRAFIA

Ja que els principis de funcionament d'aquest són coneguts normalment, però en el cas de no conèixer la clau no podrem desxifrar el missatge:

1. Si el sistema no és **teòricament** irrompible, almenys ha de ser-ho en la **pràctica**.
2. L'efectivitat del sistema **no ha de dependre** que el seu **disseny** romanguí en secret.
3. La **clau** ha de ser **fàcilment memoritzable** de manera que no calgui recórrer a notes escrites.
4. Els **criptogrames** hauran de donar resultats alfanumèrics.
5. El sistema ha de ser **operable** per una **única persona**.
6. El sistema ha de ser **fàcil d'utilitzar**.

Màxima de Shannon: *l'adversari coneix el sistema.*

5. CRIPTOGRAFIA

Criptografia Simètrica

La **criptografia simètrica** és un mètode criptogràfic en el qual s'utilitza una **mateixa clau per xifrar i desxifrar missatges**. Les dues parts que es comuniquen han de posar-se d'acord en la clau que utilitzaran.

Un bon sistema de xifrat posa tota la seguretat en la clau no en l'algorisme. És per això que la clau ha de ser molt complicada d'esbrinar.

Per aconseguir-ho, hem de tenir en compte la **longitud i el conjunt de caràcters** que s'utilitzi.

Actualment els ordinadors són molt potents i poden desxifrar una clau amb molta velocitat, per això la mida de la clau és molt important.

5. CRIPTOGRAFIA

Alguns dels algorismes de xifrat simètric són:

- **Algorisme de xifrat DES:** utilitza una clau de **56 bits**, és a dir que hi han $2^{56} = 72.057.594.037.927.936$ claus possibles. Però un ordinador normal ho pot desxifrar en qüestió de dies.
- Algorismes de xifrat **3DES**, **Blowfish** i **IDEA**: utilitzen claus de **128 bits**, és a dir 2 claus possibles (les targetes de crèdit i altres mitjans de pagament electrònic tenen com a estandar l'algorisme 3DES).
- Algorismes de xifrat **RC5** i **AES** : Aquest últim conegut també com a **Rijndael** és l'estandar de xifrat del govern dels Estats Units. (*A manera d'exemple: Desxifrar una clau de 128 bits AES amb un supercomputador estàndard actual, portaria més temps que la presumpta edat de l'univers*).

5. CRIPTOGRAFIA

Els principals problemes d'aquest sistema de xifrat no és la seva seguretat, sinó:

- **L'intercanvi de claus:** Quan l'emissor i el receptor han intercanviat les claus podran comunicar-se amb seguretat, però quin **canal de comunicació segur han utilitzat** per l'intercanvi de claus? Si un atacant intercepta l'intercanvi de claus, ja podrà desxifrar qualsevol missatge que s'envii.
- **El nombre de claus que es necessiten:** per un grup de persones reduït que necessiten comunicar-se entre sí aquest sistema podria funcionar. Però si és gran seria impossible portar-ho a terme ja que es necessiten **$n/2$** (n = nombre de persones que s'han de comunicar entre sí) claus per a cada parella de persones que intervinguin.

5. CRIPTOGRAFIA

Per tan per solucionar aquests problemes utilitzarem la **criptografia asimètrica** i la **híbrida**.

Exemple de criptografia simètrica amb la comanda **GPG**:

Crear un fitxer encriptat a partir d'un document:

```
$ gpg -c document
```

Ens generarà un arxiu **document.gpg** en format binari

Si volem generar un arxiu en encriptat en ASCII utilitzarem el modificador -a:

```
$ gpg -ca document
```

Ens generarà un arxiu **document.asc**

Per desencriptar l'arxiu: **\$ gpg -d document.gpg** o **\$ gpg -d document.asc**

5. CRIPTOGRAFIA

Criptografia de clau Asimètrica

En aquest cas s'utilitza un parell de claus, una per xifrar i una per desxifrar:

- **Clau Privada:** estarà disponible només per al seu propietari i no es donarà a conèixer a ningú més.
- **Clau pública:** serà coneguda per tots els usuaris.

Aquest dues són claus complementaries, el que xifra una ho desxifra l'altre i al revés. s'obtenen mitjançant algorismes i operacions matemàtiques complexes, és gairebé impossible conèixer una clau sense l'altre.

5. CRIPTOGRAFIA

Les dues branques principals de criptografia clau pública són:

- **Xifratge amb clau pública:** un missatge xifrat amb la clau pública d'un receptor no pot ser desxifrat per ningú tret del receptor que posseeix la clau privada corresponent. Això s'utilitza per assegurar la confidencialitat.
- **Signatura digital:** un missatge signat (xifrat) amb la clau privada d'un remitent pot ser verificat (desxifrat) per qualsevol que té accés a la clau pública del remitent, demostrant així que el remitent és qui l'ha signat (xifrat) i que el missatge no s'ha manipulat(perquè la clau pública només pot servir per desxifrar el missatge si s'ha xifrat amb la clau privada que no coneix ningú més i si no ha estat alterat). Això s'utilitza per assegurar l'autenticitat.

5. CRIPTOGRAFIA

Aquest sistema de xifrat de clau pública, es basen en funcions resum o funcions **hash** (els algorismes més comuns utilitzats com a funcions hash són **MD5 i SHA**) d'un únic sentit que aprofiten propietats particulars, per exemple dels nombres primers. Una **funció d'un sol sentit** és aquella en la qual la seva computació és fàcil, mentre que la seva inversió resulta extremadament difícil.

En GNU/Linux, podem utilitzar l'aplicació **md5sum** per calcular-nos el valor resum (o Hash) d'un arxiu (En Windows podem utilitzar l'aplicació **md5sum.exe**).

```
$ md5sum document.txt
```

Ens mostrarà **fc851301032be1df24da571c053c0fc9 document.txt**

5. CRIPTOGRAFIA

Ara per poder validar la integritat del fitxer per assegurar-nos que no ha estat modificat guardarem el resultat en un arxiu nomhash.md5. Després validarem que l'arxiu no ha estat modificat i per últim el modificarem i tornarem a fer la comprovació del md5:

```
$ md5sum document.txt > nomhash.md5
```

```
$ md5sum -c nomhash.md5
```

```
document.txt: CORRECTE
```

```
$ echo "modificacio del fitxer" >> document.txt
```

```
$ md5sum -c nomhash.md5
```

```
document.txt: INCORRECTE
```

```
md5sum: avís: 1 de 1 suma calculada NO coincideix
```

5. CRIPTOGRAFIA

En un atac de força bruta sobre un xifrat de clau pública amb una clau de mida de 512 bits, l'atacant ha de factoritzar un nombre compost codificat amb 512 bits. Mentre que 128 bits és suficient per xifrats simètrics, donada la tecnologia de factorització d'avui en dia, es recomana utilitzar **claus públiques de 1024 bits** per la majoria de casos.

La major avantatge de la criptografia asimètrica es que es pot xifrar amb una clau i desxifrar amb l'altre, però aquest sistema té desavantatges:

- Per una mateixa longitud de clau i missatge, requereix **major temps de procés**.
- Les **claus han de ser de major mida** que les simètriques.
- El missatge xifrat **ocupa més espai** que l'original.

5. CRIPTOGRAFIA

En un atac de força bruta sobre un xifrat de clau pública amb una clau de mida de 512 bits, l'atacant ha de factoritzar un nombre compost codificat amb 512 bits. Mentre que 128 bits és suficient per xifrats simètrics, donada la tecnologia de factorització d'avui en dia, es recomana utilitzar **claus públiques de 1024 bits** per la majoria de casos.

La major avantatge de la criptografia asimètrica es que es pot xifrar amb una clau i desxifrar amb l'altre, però aquest sistema té desavantatges:

- Per una mateixa longitud de clau i missatge, requereix **major temps de procés**.
- Les **claus han de ser de major mida** que les simètriques.
- El missatge xifrat **ocupa més espai** que l'original.

5. CRIPTOGRAFIA

La criptografia asimètrica està implementada en algorismes com Diffie-Helman, RSA, DSA, ElGamal.

Eines de software com PGP o en comunicacions TCP/IP, protocols com SSH o la capa de seguretat TLS/SSL, utilitzen un **xifrat híbrid** format per la **criptografia asimètrica per intercanviar claus simètriques** i la **criptografia simètrica per a la transmissió de la informació**.

Exemple de generació de parell de claus amb la comanda gpg en GNU/Linux:

Creació de claus

```
$ gpg --gen-key
```

Llistar claus públiques

```
$ gpg --list-keys o $ gpg -k
```

5. CRIPTOGRAFIA

Llistar claus privades

```
$ gpg --list-secret-keys
```

Ara cal fer pública la clau:

```
$ gpg --keyserver pgp.mit.edu --send-keys ClauID
```

ClauID és l'identificador de la clau que acabem de crear

pgp.mit.edu és una web on es publiquen claus públiques.

Per buscar claus públiques:

```
$ gpg --keyserver NomDelServidor --search-keys ClauID
```

5. CRIPTOGRAFIA

Per baixar-nos una clau pública:

```
$ gpg --keyserver NomDelServidor --recv-keys ClauID
```

Per copiar la nostra clau pública, executarem:

```
$ gpg --armor --output FitxerDeClau --export ClauID
```

Per fer una còpia de seguretat de la nostra clau privada:

```
$ gpg --armor --output FitxerDeClau --export-secret-key ClauID
```

Per revocar la nostra clau pública:

```
$ gpg -o revocacio.asc --gen-revoke ClauID
```

Per importar una clau:

```
$ gpg --import FitxerdeClaus
```

5. CRIPTOGRAFIA

La informació de GPG és guarda a la carpeta:

/home/[nom usuari]/.gnupg

La clau privada és guarda a:

~/.gnupg/secring.gpg

i la pública a:

~/.gnupg/pubring.gpg

5. CRIPTOGRAFIA

Signatura Digital

La signatura digital és un mecanisme de xifrat per autenticar informació digital. El mecanisme utilitzat és la **criptografia de clau pública**. Per això aquest tipus de signatura també rep el nom de signatura digital de clau pública.

S'utilitza també el terme signatura electrònica com a sinònim de signatura digital, tot i que la signatura electrònica inclouria també altres mecanismes per identificar l'autor d'un missatge electrònic que no són purament criptogràfics.

5. CRIPTOGRAFIA

Signatura Digital

La signatura digital és un mecanisme de xifrat per autenticar informació digital. El mecanisme utilitzat és la **criptografia de clau pública**. Per això aquest tipus de signatura també rep el nom de signatura digital de clau pública.

S'utilitza també el terme signatura electrònica com a sinònim de signatura digital, tot i que la signatura electrònica inclouria també altres mecanismes per identificar l'autor d'un missatge electrònic que no són purament criptogràfics.

5. CRIPTOGRAFIA

Hi ha tres motius per utilitzar signatures digitals en les comunicacions:

- **Autenticitat:** Un sistema criptogràfic de clau pública permet a qualsevol enviar missatges utilitzant una clau pública. La signatura permet al receptor d'un missatge estar segur que el remitent és qui diu ser. Tot i així, el receptor no pot estar completament segur que el remitent és qui diu ser ja que el sistema criptogràfic es pot haver trencat.
- **Integritat:** Emissor i receptor voldran estar segurs que el missatge no s'ha alterat durant la transmissió.
- **No repudiació:** En un context criptogràfic, la paraula repudiació fa referència a l'acció de negar la relació amb un missatge (per exemple dient que ha estat enviat per un tercer). El receptor d'un missatge pot insistir que l'emissor adjunti una signatura per prevenir que més endavant l'emissor pugui repudiar el missatge, així, el receptor pot mostrar el missatge a un tercer i provar el seu origen.

5. CRIPTOGRAFIA

La signatura digital és un **xifrat del missatge** que està firmant però utilitzant la **clau privada** en lloc de la pública.

Exemple de signatura digital amb **gpg** en GNU/Linux (parell de claus creada abans):

Signem el document però no el xifrem

```
$ gpg --clearsign [document]
```

Signem el document i el xifrem en un arxiu binari:

```
$ gpg -s [document]
```

Signem i xifrem, però el missatge i signatura van en fitxers separats:

```
$ gpg -b [document]
```

Per verificar la validesa de la signatura digital: **\$ gpg --verify [document]**

5. CRIPTOGRAFIA

Certificat Digital

Un **Certificat Digital** és un document digital mitjançant el qual un tercer fiable (una [autoritat de certificació](#)) garanteix la vinculació entre la identitat d'un subjecte o entitat i la seva clau pública.

Si voleu utilitzar el vostre certificat digital i que sigui vàlid, cal que primer aneu a una autoritat certificadora. Us haureu d'identificar correctament i, tot seguit, ells certificaran que sou qui dieu ser i us donaran el certificat digital corresponent. Aleshores, quan envieu missatges que vulgueu que us identifiquin davant altres persones, només caldrà que hi afegiu una còpia pública del vostre certificat digital. D'aquesta manera, la persona que rebi el missatge sabrà de segur que l'emissor del missatge és qui diu ser, garanteix altres persones, entitats, o administracions públiques quina és la vostra identitat.

5. CRIPTOGRAFIA

El format més comunament emprat és l'estàndard [X.509](#) i la seva distribució és possible realitzar-la:

- **Amb clau privada** (acostuma a tenir extensió ***.pfx** o ***.p12**), més segur i destinat a una utilització privada d'exportació i importació posterior com a mètode de còpia de seguretat.
- **Només amb clau pública** (acostuma a ser extensió ***.cer** o ***.crt**), destinat a la distribució no segura, per a que altres entitats o usuaris només puguin verificar la identitat, en els arxius o missatges signats.

5. CRIPTOGRAFIA

Un certificat emès per una **entitat de certificació autoritzada**, a més d'estar signat digitalment per aquesta, **ha de contenir** almenys el següent:

- Nom, adreça i domicili del subscriptor.
- Identificació del subscriptor nomenat en el certificat.
- El nom, l'adreça i el lloc on realitza activitats l'entitat de certificació.
- La clau pública de l'usuari.
- La metodologia per a verificar la signatura digital del subscriptor imposada en el missatge de dades.
- El nombre de sèrie del certificat.
- Data d'emissió i expiració del certificat.

5. CRIPTOGRAFIA

Entre les **aplicacions** dels certificats digitals i el DNIE trobem, realitzar compres i comunicacions segures, com tràmits amb la banca online, amb l'administració pública (hisenda, seguretat social, etc) a través d'Internet, etc.

DNIE

El desenvolupament de la Societat de la Informació i la difusió dels efectes positius que d'ella es deriven exigeixen la **generalització de la confiança dels ciutadans en les comunicacions telemàtiques**.

Com a resposta a aquesta necessitat, i en el marc de les directives de la Unió Europea, l'Estat espanyol ha aprovat un conjunt de mesures legislatives, com la [Llei de Signatura Electrònica](#) i el [RD sobre el Document Nacional d'Identitat electrònic](#), per a la **creació d'instruments capaços d'acreditar la identitat dels intervinents en les comunicacions electròniques i assegurar la procedència i la integritat dels missatges intercanviats**.

5. CRIPTOGRAFIA

El naixement del Document Nacional d'Identitat electrònic (**DN_{Ie}**) respon, per tant, a la necessitat d'atorgar identitat personal als ciutadans per al seu ús en la nova Societat de la Informació, a més de servir d'impulsor de la mateixa. Així, el **DN_{Ie}** és l'adaptació del tradicional document d'identitat a la nova realitat d'una societat interconnectada per xarxes de comunicacions.

D'aquesta manera, cada ciutadà podrà fer realitzar múltiples gestions de forma segura a través de mitjans telemàtics i assegurant la identitat dels participants en la comunicació.

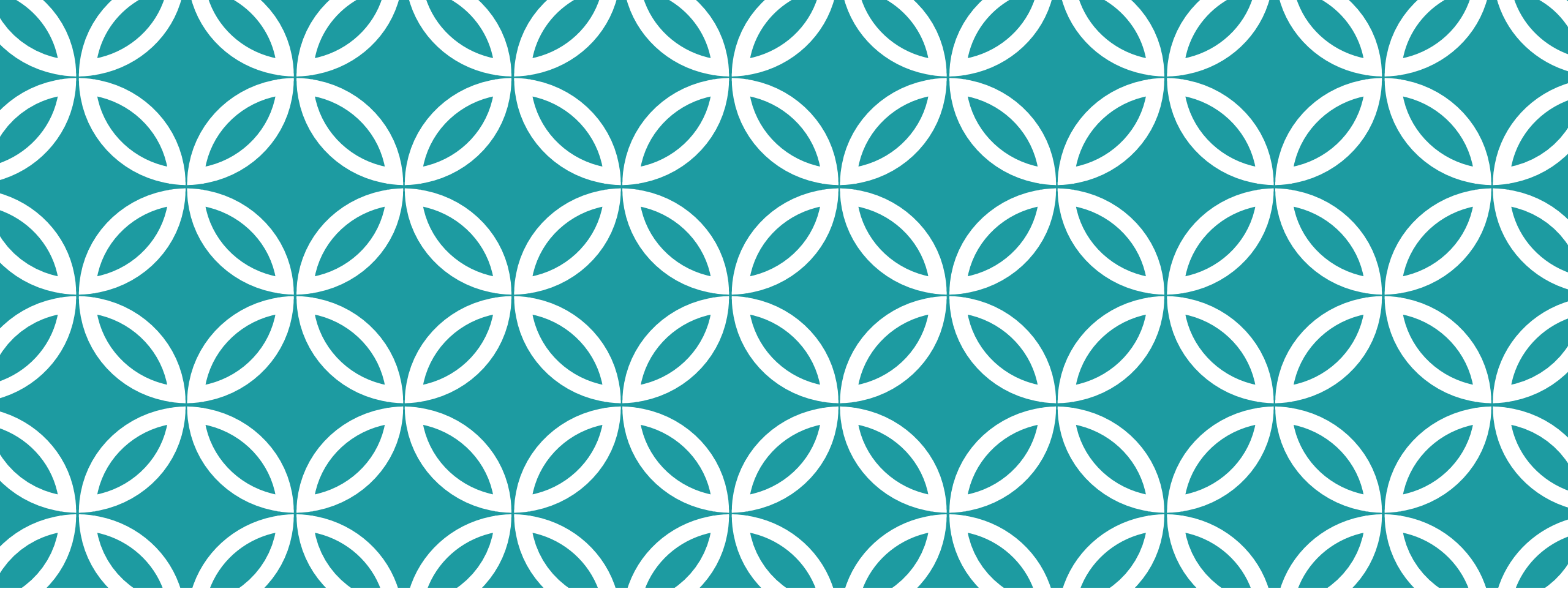
5. CRIPTOGRAFIA

És semblant al DNI clàssic amb la novetat que incorpora un xip capaç de guardar de manera segura:

- Un certificat electrònic per autenticar la personalitat del ciutadà.
- Un certificat electrònic per signar electrònicament, amb la mateixa validesa jurídica que la signatura manuscrita.
- Certificat de l'Autoritat de Certificació emissora.
- Claus per la seva utilització.
- La plantilla biomètrica de la impressió dactilar.

Per utilitzar el DNIE es necessari tenir:

- **Hardware específic:** lector de targetes intel·ligents que compleixin l'**ISO-7816**.
- **Software específic:** En **Windows** és el servei *Cryptographic Service Provide (CSP)*, i en **GNU/Linux o MAC** el mòdul *PKCS#11*.



6. LEGISLACIÓ

6. LEGISLACIÓ

Normativa legal en matèria de seguretat informàtica

La **lleï orgànica 15/1999 de protecció de dades de caràcter personal (LOPD)** és una llei orgànica que té com objectiu **garantir i protegir les dades personals**, les **llibertats públiques** i els **drets fonamentals** de les persones físiques, i especialment la seva **intimitat i privadesa personal** i familiar.

Fou aprovada a les Corts espanyoles el 13 de desembre del 1999. Aquesta llei es desenvolupa fonamentada en l'article 18 de la **Constitució espanyola de 1978**, sobre el dret a la **intimitat familiar i personal**; i el **secret de les comunicacions**.

6. LEGISLACIÓ

Aquesta llei afecta a totes les dades que fan referència a persones físiques registrades sobre **qualsevol suport, informàtic o no**. Queden exempts del compliment d'aquesta normativa aquelles dades recollides per a ús domèstic, les matèries classificades de l'estat i aquells fitxers que recullen dades sobre terrorisme i altres formes de delinqüència organitzada (no simple delinqüència).

A partir d'aquesta llei es varen formar l'**Agència Espanyola de Protecció de Dades**, d'àmbit estatal, i l'**Agència Catalana de Protecció de Dades**, en l'àmbit de Catalunya, que vetllen pel compliment d'aquesta normativa.

6. LEGISLACIÓ

Nivells de la LOPD

Les **dades de caràcter personal** s'estructuren en **diferents nivells** que classifiquen els registres en tres nivells de seguretat. Ho són:

- noms i cognoms de persones físiques vives
- números de DNI, NIF i passaport
- adreces físiques que s'hi associïn o s'hi puguin associar a través del tractament informàtic
- telèfons i adreces de correu electrònic que s'hi associïn o s'hi puguin associar a través del tractament informàtic
- fotografies on es pugui reconèixer clarament algú.

6. LEGISLACIÓ

- veu a través de la qual es pugui reconèixer algú
- dades genètiques i mèdiques associades a persones concretes
- dades biomètriques
- dades referides a creences, filiació política o sindical
- dades referides a la raça
- qualsevol dada que permeti identificar algú (la llei no opta per una enumeració tancada, sinó per la definició anteriorment exposada; per tant, la intenció és atorgar el màxim de protecció possible atesos els continus avenços de la ciència i la tècnica)

6. LEGISLACIÓ

Nivell bàsic

- Identificatiu.
- Personal.
- Circumstàncies socials.
- Acadèmics i professionals.
- Detall d'empleats.
- Informació comercial
- Econòmic-financer i d'assegurances
- Transacció

6. LEGISLACIÓ

Nivell mitjà

- Infraccions administratives o penals.
- Hisenda pública.
- Serveis Financers.
- Solvència patrimonial i crèdits.
- Avaluació de la personalitat.

6. LEGISLACIÓ

Nivell alt

- Ideologia.
- Creences.
- Origen racial.
- Salut.
- Vida sexual.

6. LEGISLACIÓ

Principals elements derivats de la legislació espanyola

Conceptes legals previs:

La Constitució espanyola de 1978 fa referència en **3 articles** al tractament de les dades, tot i que la jurisprudència reconeix que no es pronuncia clarament:

- **Article 18.4:** El legislador va deixar clar que la llei ha de **limitar l'ús de la informàtica** per tal de garantir l'honor i la intimitat personal i familiar dels ciutadans i el ple exercici dels seus drets.
- **Article 20.1:** **Dret a comunicar o rebre** lliurement informació.
- **Article 105.b:** La llei regularà l'**accés dels ciutadans als arxius i registres** (Llei 30/1992).

6. LEGISLACIÓ

S'ha de tenir en compte, que al regular un dret fonamental segons la Constitució la seva aprovació ha de ser per llei orgànica, el que suposa tenir la majoria absoluta al Congrés dels Diputats.

Àmbit d'Aplicació

La LOPD estableix, en línies generals, que la llei és **aplicable a totes aquelles empreses i administracions que donin servei a ciutadans dins del territori espanyol** (Per exemple afectaria a una empresa que donés servei a ciutadans espanyols des de qualsevol lloc del món).

6. LEGISLACIÓ

Per contra la llei **no afecta** a:

- Fitxers mantinguts per persones físiques en exercici exclusivament personal o domèstic.
- Fitxers de matèries classificades.
- Fitxers establerts per a la investigació de terrorisme i de delictes greus relacionats amb la delinqüència organitzada.
- Persones ja mortes.

6. LEGISLACIÓ

Objecte

L'article 1 de la Llei Orgànica 15/99 de Protecció de dades **estableix**: "*La present Llei Orgànica té per objecte garantir i protegir, en allò referent al tractament de les dades personals, les llibertats públiques i els drets fonamentals de les persones físiques, i especialment del seu honor i intimitat personal i familiar*".

En **l'article 2** de la citada Llei se n'estableix la competència i àmbit d'aplicació. La **manca de concreció** de la pròpia llei ha fet que es generin molts dubtes al voltant de determinades definicions i aspectes normatius de la mateixa. En tot cas resulta evident la necessitat que té el legislador de protegir les dades personals, en el sentit de desenvolupar i garantir el dret fonamental a la intimitat així com establir una legislació de control sobre el tràfic i gestió de les dades personals dels ciutadans.

6. LEGISLACIÓ

Conceptes bàsics

- **Dada Personal:** qualsevol informació del tipus que sigui **que permeti identificar** o faci identificable la **persona física** (no la persona jurídica).
- **Afectat:** persona identificada o identificable a qui corresponen les dades personals.
- **Fitxer:** Tot **conjunt organitzat de dades** de caràcter personal, que permeti accés a les dades amb criteris determinats, qualsevol que sigui la forma o modalitat de creació, enregistrament, organització, tractament i accés.
- **Responsable del fitxer:** **persona física o jurídica** de naturalesa pública o privada a qui pertany el fitxer, amb independència que executi o no materialment el tractament.

6. LEGISLACIÓ

- **Sistema de Tractament:** qualsevol forma o modalitat que permeti l'ús i gestió de les dades, des que es **registren** fins que s'**eliminen**.
- **Encarregat de Tractament:** pot ser el responsable del fitxer o qualsevol altra persona física o jurídica de naturalesa privada o pública que tracti per encàrrec del responsable les dades de caràcter personal dels fitxers.

6. LEGISLACIÓ

Alhora, aquest encarregat de tractament pot fer-ho sol o conjuntament i en cada cas estan tots els agents implicats obligats a la normativa de confidencialitat desenvolupada.

- **Usuari:** qualsevol **persona que tingui accés** a les dades personals que componen el o els fitxer/s del responsable.
- **Responsable de Seguretat:** persona o persones **físiques o jurídiques** que tenen la funció de vetllar pel compliment, aplicació i manteniment del document de seguretat.

6. LEGISLACIÓ

- **Document de seguretat: recull de normativa i processos** per a l'**aplicació dels aspectes regulats** en matèria de protecció de dades que tot **Responsable de Fitxer** ha de tenir obligatòriament.
- **Comunicació de dades:** qualsevol **cessió de les dades** personals del responsable del fitxer **a tercers**. Tota comunicació o cessió de dades entre parts s'ha de donar en un marc regulat entre les parts de confidencialitat estricta i s'han de garantir l'aplicació de les mesures de seguretat corresponents així com que les dades seran tractades per a la finalitat amb que van ser registrades, amb l'excepció dels requeriments de determinades administracions públiques relacionades amb les funcions policials, de justícia i sanitat.

6. LEGISLACIÓ

Fitxer de dades personals

És el punt de partida de la normativa.

Un **fitxer** serà **qualsevol conjunt organitzat de dades personals**, de propietat pública o privada, qualsevol que sigui la seva forma d'enregistrament i tractament amb una finalitat determinada.

No ha estat fins al **RDLOPD** que s'ha concretat que el sistema de tractament en paper constitueix també un fitxer. Per tant, tota entitat de dret públic o privat té fitxers que contenen dades personals registrades per a diferents finalitats. Cal identificar-los i classificar-los per funcionalitat i naturalesa i registrar-los públicament.

6. LEGISLACIÓ

Totes les **mesures de seguretat** que es desenvolupen s'han d'aplicar sobre els fitxers en funció del seu sistema de tractament.

Són així l'element central en matèria de protecció de dades personals, ja que són el conjunt de dades registrades i tractades per a una o varies finalitats concretes.

En qualsevol suport. I és propietat del responsable del fitxer, que és qui ha d'assumir l'aplicació de la normativa corresponent sobre els fitxers.

6. LEGISLACIÓ

Qualitat de la dada i nivells de seguretat

L'**article 4.1** de la **LOPD** estableix que: *les dades de caràcter personal només es podran recollir pel seu tractament, així com sotmetre'ls al citat tractament, quan siguin **adequades, pertinents i no excessives** en relació amb l'àmbit i les finalitats determinades, explícites i legítimes per les que s'hagin obtingut.*

La **LOPD** defineix quina és la qualitat de la dada, en base a la qual s'estableixen els nivells de seguretat que sobre el seu tractament cal aplicar i que desenvolupa el **RDLOPD**. Això tindrà implicacions respecte el sistema de tractament i també respecte els usuaris (control d'accessos, registre, identificació, autenticació, compromís de confidencialitat del personal, etc.).

6. LEGISLACIÓ

En tot cas, els nivells es defineixen en tres nivells:

- **Nivell Bàsic:** qualsevol fitxer que contingui dades personals de qualsevol tipus que facin **identificable** la persona: nom, imatge, adreça, etc.
- **Nivell Mitjà:** fitxers que continguin, **a més de les anteriors**, dades relatives a la **comissió d'infraccions administratives o penals, hisenda pública, serveis financers i aquells corresponents a la prestació de serveis de solvència i crèdit**. Generalment, però s'entén que estarem davant dades de nivell mitjà quant aquestes permetin fer una valoració d'entorn social i psicològic de la persona, més enllà de la seva simple identificació.
- **Nivell Alt:** fitxer que contingui dades personals sobre **ideologia, religió, creences, origen racial, salut o vida sexual o els registrats per a fins policials sense consentiment**. Aquestes son les dades que han de ser especialment protegides.

6. LEGISLACIÓ

En funció del nivell de dades registrades en el fitxer amb un o altre sistema de tractament, caldrà aplicar unes mesures de seguretat concretes que es desenvolupen al **RDLOPD** per a cada un dels nivells.

Igualment, el règim sancionador és diferent en funció de la qualitat de la dada implicada en la infracció.

De manera que la normativa protegeix especialment les dades qualificades com a nivell alt, que tenen una especial relació amb els drets fonamentals de les persones.

6. LEGISLACIÓ

Registre de fitxers

Tot responsable de fitxer haurà de registrar a L'Agència Espanyola de Protecció de Dades tots fitxers com tingui identificats. No tenir els fitxers registrats és una primera infracció.

Això té nombroses implicacions i obligacions concretes per als responsables de fitxer i alhora suposa una garantia mínima de qualitat per la persona respecte de les seves dades personals.

El registre de fitxers és d'accés públic i el que es comunica a l'agència és la identificació del fitxer, el contingut de les dades (la seva qualitat) així com la finalitat i cessions que se'n facin i la identificació de tercers implicats en la gestió i/o tractament de les dades. No es comuniquen les dades concretes, sinó la seva composició per a cada un dels fitxers. I es fa a través de l'aplicació informàtica única que l'agència disposa públicament.

6. LEGISLACIÓ

Consentiment informat i drets

Aquest és un altre element cabdal de la legislació, regulat en l'**article 6 de la LOPD**. En el moment que es recull la dada de caràcter personal el responsable del fitxer ha de fer-ho **obtenint el consentiment informat de l'afectat**.

Alhora, ha d'informar la persona afectada, com a mínim, dels següents aspectes:

- **Identitat del Responsable del Fitxer** i advertència de l'existència de fitxer on seran registrades les dades.
- Dels **drets que assisteixen l'afectat** respecte de les seves dades personals: **accés, rectificació, cancel·lació i oposició**.
- De la **finalitat amb què són recollides** i de l'ús que se'n donarà, així com de possibles cessions a tercers.

6. LEGISLACIÓ

Nombrosos procediments sancionadors s'han iniciat per incompliments d'aquests elements que recullen els **articles 5 i 6 de la LOPD**, bàsicament per cessions de dades no informades o per l'ús de finalitats diferents per a les que es van registrar i no informades en el moment de recollida de la dada, ni tampoc captat el consentiment necessari per a la cessió.

Són moltes les implicacions que es poden derivar d'aquesta obligació i molts els casos en que es vulnera, com es pot comprovar sobre el total de procediments sancionadors que disposa públicament l'agencia espanyola de protecció de dades on identifica l'article o articles concrets que s'han vulnerat.

A la pràctica, els responsables de fitxer han optat per incloure clàusules generals en formularis de recollida de les dades personals. Que en un o altre moment verifiquen que l'afectat hagi **signat o acceptat de forma explícita o tàcita**.

6. LEGISLACIÓ

La llei però també estableix una sèrie d'excepcions en les que **no és necessari demanar consentiment informat**:

- Quan la llei digui el contrari.
- Quan es recullen "fonts accessibles al públic".
- Quan el destinatari sigui el Defensor del poble, el Ministeri fiscal espanyol o la judicatura, el Tribunal de comptes, el Síndic de Greuges, la Sindicatura de Comptes, etc.
- Quan la cessió de dades sigui entre administracions llevat que el motiu pel qual es van recollir sigui diferent al motiu pel qual es cedeixen.
- Quan la cessió de dades de salut sigui per motiu d'urgència.

6. LEGISLACIÓ

- Quan es refereixi a persones vinculades per una relació comercial, laboral o administrativa i siguin necessàries pel manteniment de les relacions o quan el tractament respongui a la lliure i legítima acceptació d'una relació, el desenvolupament, compliment i control de la qual impliqui necessàriament la connexió d'aquest tractament amb fitxers de tercers.

La respecte els drets dels titulars de les dades, aquests es coneixen com a drets ARCO.

6. LEGISLACIÓ

Comunicació i cessió de dades personals a tercers

Es desprèn dels **articles 11 i 12** de la **LOPD**.

La cessió també ha de tenir el coneixement i consentiment de l'afectat i això no sempre és així.

Aquesta obligació adquireix especial rellevància en el context actual de subcontractació de serveis per les entitats. De manera que podria ser que la dada fos recollida per un responsable del fitxer i que després fos **cedida a un tercer per a un tractament específic**.

Per exemple, les dades d'uns treballadors passades al servei contractat d'assessoria laboral, sense coneixement ni consentiment dels afectats, podrien ser posteriorment utilitzades per enviar-los publicitat comercial de serveis.

6. LEGISLACIÓ

En qualsevol comunicació o cessió de dades, per a tractament o no, hi ha d'haver un contracte entre el responsable del fitxer i aquest tercer encarregat del tractament on s'estableixin **quines són les finalitats del tractament** i on l'encarregat del tractament es compromet a complir amb la normativa vigent en matèria de protecció de dades.

Resulta doncs una garantia força important per a l'afectat i en el recull de processos sancionadors de l'Agència Espanyola trobem importants sancions econòmiques per cessió il·legal de dades.

L'**article 9** de la **LOPD** estableix que el responsable del fitxer i en el seu cas l'encarregat del tractament seran els responsables d'aplicar les mesures de seguretat en les dades.

6. LEGISLACIÓ

Confidencialitat del personal

Ll'article 10 de la **LOPD**, estableix: *"El responsable del fitxer i aquells que intervinguin en qualsevol fase del tractament de les dades de caràcter personal resten obligats al **secret professional** respecte dels mateixos i al deure de guardar-los, obligacions que subsistiran encara després de finalitzar les seves relacions amb el titular del fitxer o, en el seu cas, amb el responsable del mateix."*

Resulta aquest un altre dels articles la vulneració del qual és centra una bona part dels processos sancionadors que instrueix l'agència espanyola.

6. LEGISLACIÓ

Doncs implica una diversitat molt extensa d' àmbits i es una obligació general que recau sobre qualsevol usuari que tingui accés a les dades de qualsevol fitxer del responsable o encarregat del tractament. És la prova de la responsabilitat en aplicar les mesures de seguretat al fitxer no només per part de l'entitat responsable sinó també pel seu personal i càrrecs, així com pels possibles encarregats de tractament.

També en aquest cas els responsables del fitxer han anat optant majoritàriament per establir clàusules generals d'obligació a la confidencialitat en els contractes laborals del personal, amb col·laboradors, tercers, etc.

6. LEGISLACIÓ

Règim sancionador

El règim sancionador establert per la legislació espanyola és més estricte en comparació amb altres de països veïns.

Dependrà en tot cas de la infracció comesa i especialment de la qualitat de la dada implicada, però el nivell econòmic de les sancions se situa, en funció del grau de la infracció, en:

- Sanció per **infracció lleu** : de 601,01 € a 60.101,21 €
- Sanció per **infracció greu** : de 60.101,21 € a 300.506,05 €
- Sanció per **infracció molt greu**: de 300.506,05 € a 601.012,10 €

6. LEGISLACIÓ

La prescripció de les sancions i de les infraccions és el següent:

- Lleus : 1 any
- Greus : 2 anys
- Molt greus: 3 anys

En el cas de la prescripció de les sancions s'han de tenir en compte uns factors i en el cas de la prescripció de les infraccions uns altres que poden fer variar aquests períodes.

6. LEGISLACIÓ

No obstant, el procediment sancionador no és el mateix per a les **entitats de dret privat** que per a l'**administració pública**.

En cas que sigui l'administració la que cometi una infracció el procediment passarà per una investigació que pot concloure amb sancions disciplinàries sobre l'òrgan i els càrrecs infractors, però **no amb sanció econòmica** (els diners sortirien de la hisenda pública per anar a parar a la hisenda pública).

Però segons la qualificació de les dades que fa la pròpia llei, és precisament l'administració la que posseeix dades de major qualitat: serveis sanitaris, educatius, tributaris, etc.. Per aquesta raó seria desitjable que la normativa s'adaptés de forma immediata, per garantir els drets dels afectats.

6. LEGISLACIÓ

El **Títol VII de la LOPD** configura tant la naturalesa de la infracció com el procediment i sancions disposades en la matèria, tot establint una distinció en quant al procés sancionador si la infracció és comesa per entitats de dret públic, administracions públiques, o de dret privat, la resta.

De manera que en el primer cas parlarem d'amonestacions i procediments disciplinaris i en el segon de sancions econòmiques.

A més, cal pensar que, com es desprèn de l'**article 44** que defineix els tipus i gravetat de les infraccions, a l'analitzar el conjunt de resolucions dels procediments, en la majoria dels casos ens trobem davant una infracció que *com a mínim serà greu* i que partirà doncs d'una sanció econòmica *mínima de 60.101,21 €*.

6. LEGISLACIÓ

Document de Seguretat

És el document que tot responsable de fitxer ha de elaborar i disposar on es reculli el processos que donen compliment internament a la normativa.

On figura un responsable de seguretat, la identificació i registre dels **fitxers**, la **normativa aplicable**, el **registre d'usuaris**, de **suports**, l'**inventari** de sistemes d'informació i aplicacions, i tot allò relacionat amb la implantació a l'entitat de la normativa.

És un document de garantia mínima de compliment amb les obligacions derivades de la normativa que tota entitat hauria de disposar, però que per si mateix no implica el compliment de les mesures de seguretat.

6. LEGISLACIÓ

Implicacions i futur

El desenvolupament a través de la Llei Orgànica del conjunt de drets i deures que suposa la garantia legal de protecció de les nostres dades personals té nombroses implicacions. En primer lloc hem de veure tot aquest marc normatiu com a un **conjunt de garanties respecte de l'ús de les dades personals per part dels responsables del fitxer**. En el sentit que hem d'estar **informat**s de per a què es recullen les nostres dades i de **quin serà el destí** de les mateixes, alhora de garantir-nos l'exercici dels drets d'**accés, rectificació, cancel·lació i oposició** de les mateixes.

Igualment, el règim sancionador disposat a la llei suposa una **amença** clara per a les empreses, tot i que **desigual**. Doncs **no distingeix entre una gran corporació** que fa transferència il·legal de dades per a benefici comercial d'entre **una petita o mitjana empresa**, per la qual cosa el fet que és té en compte en imposar la sanció es la infracció i no la posició del responsable del fitxer. Això provoca que determinades corporacions empresarials amb potencial i capital suficient puguin destinar una partida del seu pressupost anual al pagament de les possibles sancions en protecció de dades, donat que el rendiment econòmic que les seves infraccions en l'àmbit de l'acció comercial serà superior al import de les eventuais sancions. Mentre que una entitat privada sense aquesta posició es veurà greument afectada.

6. LEGISLACIÓ

Tanmateix, en el context de la societat del coneixement i amb el desenvolupament i implantació al món professional de les TIC no es poden obviar les obligacions respectives dels proveïdors de serveis tecnològics i del comerç electrònic. Més encara si sabem que les cessions de dades son constants, especialment en consideració a la subcontractació de serveis de hosting, de còpies de seguretat, de processos de reconstrucció, d'assistència a distància, i un llarg etc. Per això resulta interessant vincular l'estudi de la normativa en matèria de protecció de dades amb la **Llei 34/2002, de 11 de Juliol, de Serveis de la Societat de la Informació i Comerç Electrònic (LSSI-CE)**. Especialment important per a l'aplicació de la normativa en matèria de **comerç electrònic** i d'**usos d'Internet**. És aquest un àmbit encara per descobrir i no cal dir que al legislador se li escapa de les mans, tot i que, en qualsevol cas, son creixents els procediments sancionadors de l'Agencia Espanyola de Protecció de Dades on aquesta llei i matèria son objecte de sanció.

6. LEGISLACIÓ

La regulació en matèria de Protecció de Dades Personals suposa unes garanties de drets dels afectats i alhora imposa unes obligacions als responsables dels fitxers, les mesures de seguretat a aplicar sobre els fitxers així com la garantia que tot usuari o encarregat de tractament tindrà coneixement de l'existència de la normativa i adquirirà un compromís de confidencialitat. Però si s'analitza al detall tota la regulació, que des del **RDLOPD** és quelcom més concreta, cal adonar-se que el seu **compliment íntegre es pràcticament impossible**. I, donat que el règim sancionador disposat es molt dur, no és d'estranyar que l'aparició d'aquesta normativa hagi suposat una **nova quota de mercat per a empreses de serveis d'assessorament i consultoria** que, arrel de la preocupació que genera aquesta qüestió i afegint l'exigència dels estàndards de qualitat internacionals, no pot fer més que créixer. Igualment, també el creixement de serveis destinats a la destrucció de documentació, gestió d'arxius, allotjament de dades remots, serveis de reconstrucció, etc.

6. LEGISLACIÓ

I és que la protecció de dades entesa de forma global afectat tots els tipus d'activitat i el seu àmbit d'aplicació es constant i creixent, doncs les dades personals son la base de les relacions de servei. Al mateix ritme, per tant, es van desenvolupant tot un seguit de novetats tecnològiques i de formació per a professionals al respecte. No podem separar la Protecció de Dades de l'ús de les Tecnologies de la Informació i la Comunicació, de la Signatura digital, del Certificat digital, ús d'Internet, entre d'altres eines avui habituals en el marc laboral i sobre les quals la protecció de dades té una significació molt important. En un entorn de e-administració creixent i de serveis online en creixement exponencial, la Protecció de Dades Personals jugarà un paper transcendental en els propers anys. Especialment si tenim en compte que el percentatge d'entitats, responsables de fitxer, públics i privats, que tenen fitxers registrats (primer pas per al compliment de la normativa) a les agències és insignificant encara avui.

6. LEGISLACIÓ. NOVETATS RGPD

Novetats RGPD

El Reglament General de Protecció de Dades (GDPR) (Control (UE) 2016/679) és un reglament europeu mitjançant el qual l'Eurocambra, el Consell de la Unió europea i la Comissió europea pretenen enfortir i unificar protecció de dades per tots els països de la Unió europea (UE), controlant també la transferència de dades fora de la Unió. Els seus principals objectius són retornar als ciutadans el control sobre la seva informació personal i unificar el marc regulador per a les multinacionals. Suposa una llei més estricta que altres normes i es tracta de la primera norma sobre aquesta matèria que afecta a tots els països de la Unió Europea i unifica tant els drets com les obligacions. Quan entri en vigor, la GDPR reemplaçarà a la Directiva de Protecció de Dades 95/46/EC de 1995.

Va entrar en vigor el maig de 2018. A Espanya, l'actual RGPD **va a substituir a la Llei Orgànica de Protecció de Dades de Caràcter Personal (LOPD)** aprovada per les Corts Generals el 13 de desembre de 1999, i va ser substituïda per la **Llei Orgànica de Protecció de Dades i Garantia de Drets Digitals (LOPD-GDD)** el 22 de novembre de 2018.

6. LEGISLACIÓ

Actors principals:

- **Responsable:** és la persona física o jurídica, autoritat pública, agència o un altre ens que, sol o en conjunt amb altres, **determina els propòsits i mitjans** del processament de dades personals.
- **Encarregat:** és la persona física o jurídica, autoritat pública, agència o un altre ens que **processa dades personals en nom del responsable**.

A continuació es descriuen les novetats del RGPD.

1. Àmbit d'aplicació

El Reglament amplia l'àmbit d'aplicació territorial als **responsables i als encarregats del tractament no establerts en la UE**, quan les activitats de tractament estan relacionades amb l'oferta de béns o serveis o amb el control del comportament de les **persones que es troben a la UE**.

6. LEGISLACIÓ

2. Principis

L'RGPD conté molts conceptes, principis i mecanismes similars als que estableixen la **Directiva 95/46** i les normes nacionals que l'apliquen. Per això, les organitzacions que actualment compleixen adequadament l'**LOPD** espanyola tenen una **bona base de partida** per evolucionar cap a una correcta aplicació del nou Reglament.

No obstant això, l'RGPD **modifica alguns aspectes** del règim actual i conté **noves obligacions** que cada organització ha d'analitzar i aplicar tenint en compte les seves pròpies circumstàncies.

6. LEGISLACIÓ

La innovació més gran de l’RGPD per als responsables la constitueixen dos elements de caràcter general:

El principi de “responsabilitat proactiva”

L’RGPD descriu aquest principi com la necessitat que el **responsable del tractament** apliqui **mesures tècniques i organitzatives apropiades**, a fi de garantir i poder demostrar que el tractament és conforme al Reglament.

En termes pràctics, aquest principi requereix que les organitzacions **analitzin quines dades tracten**, amb **quines finalitats** ho fan i **quin tipus d'operacions de tractament** duen a terme. A partir d'aquest coneixement, han de **determinar de manera explícita** com aplicaran les mesures que preveu l’RGPD. Així mateix, s’han d’assegurar que aquestes mesures són les adequades per complir-lo i que **poden demostrar-ne el compliment** davant les persones interessades i davant les autoritats de supervisió.

6. LEGISLACIÓ

“L’enfocament de risc”

L’RGPD assenyala que les mesures adreçades a garantir-ne el compliment han de tenir en compte la naturalesa, l’àmbit, el context i les finalitats del tractament, així com el risc per als drets i les llibertats de les persones.

D’acord amb aquest enfocament, **algunes de les mesures** que l’RGPD estableix **només s’han d’aplicar quan hi hagi un alt risc** per als drets i les llibertats, mentre que d’altres s’han de modular d’acord amb el nivell i tipus de risc que presentin els tractaments.

Per tant, l’aplicació de les mesures previstes per l’RGPD s’ha d’**adaptar a les característiques de les organitzacions**. El que pot ser adequat per a una organització que maneja dades de milions d’interessats, en tractaments complexos que involucren informació personal sensible o volums importants de dades sobre cada afectat, no és necessari per a una petita empresa que duu a terme un volum limitat de tractaments de dades no sensibles.

Aquests dos elements es projecten sobre totes les obligacions de les organitzacions.

6. LEGISLACIÓ

3. Noves categories especials de dades

A part de les dades especialment protegides que ja preveia l'LOPD, que ara passen a anomenar-se "**categories especials de dades**", el Reglament inclou dues noves categories especials de dades:

- **Dades genètiques:** dades personals relatives a les característiques genètiques heretades o adquirides d'una persona física, que proporcionen una informació única sobre la fisiologia o la salut d'aquesta persona, obtingudes en particular de l'anàlisi d'una mostra biològica.
- **Dades biomètriques:** dades personals obtingudes a partir d'un tractament tècnic específic, relatives a les característiques físiques, fisiològiques o conductuals d'una persona física, que permeten o confirmen la identificació única d'aquesta persona (imatges facials, dades dactiloscòpiques, etc.).

6. LEGISLACIÓ

4. Consentiment

L'RGPD requereix que l'interessat presti el consentiment mitjançant una **declaració inequívoca o una acció afirmativa clara**. Als efectes del nou Reglament, les caselles ja marcades, el **consentiment tàcit o la inacció no constitueixen un consentiment vàlid**.

Què succeeix amb els tractaments que s'efectuen sobre la base del consentiment per omissió?

Aquestes formes de consentiment **no són compatibles amb l'RGPD**, ja que es basen en la inacció de la persona interessada. L'RGPD també assenyala que els tractaments basats en el consentiment iniciats abans de l'aplicació del Reglament continuaran sent legítims, sempre que aquest consentiment s'hagués prestat de la manera que preveu el mateix RGPD, és a dir mitjançant una manifestació o acció afirmativa.

6. LEGISLACIÓ

Per tant, els responsables que efectuen tractaments basats en aquest consentiment per omissió haurien d'**evitar continuar obtenint aquesta modalitat de consentiment** i revisar aquests tractaments de manera que, a partir de maig de 2018, s'hagin adequat a les previsions de l'RGPD.

Aquesta adaptació es pot dur a terme obtenint un consentiment d'acord amb les disposicions de l'RGPD o valorant si els tractaments afectats poden tenir suport en una altra base legal, com pot ser, entre d'altres, l'interès legítim del responsable o del cessionari de les dades que prevalgui sobre els drets de l'interessat. En tot cas i si es considera que aquesta segona opció és possible, cal informar-ne els interessats, que poden exercir els drets específicament aplicables a la nova base legal triada, com el d'oposició.

6. LEGISLACIÓ

En quines situacions cal que el consentiment sigui explícit?

L'RGPD preveu algunes situacions en què el consentiment ha de ser **explícit**. Aquesta garantia addicional afecta els casos següents:

- Tractament de categories especials de dades
- Adopció de decisions automatitzades
- Transferències internacionals

Encara que les **diferències** entre el consentiment inequívoc, tal com el defineix l'RGPD, i el consentiment explícit poden semblar difícils d'apreciar, hi ha situacions en què el consentiment pot ser inequívoc i atorgar-se de forma **implícita**. Un exemple seria quan es dedueix d'una acció de la persona interessada que decideix continuar navegant per una pàgina web, i accepta així que s'utilitzin galetes (*cookies*) per monitoritzar la seva navegació.

6. LEGISLACIÓ

5. Consentiment dels menors

En l'àmbit dels serveis de la societat de la informació, el consentiment dels menors només és vàlid si tenen **més de 16 anys**. No obstant això, els estats membres de la UE **poden rebaixar l'edat fins als 13 anys**.

A més, el llenguatge utilitzat per informar-los els ha de ser comprensible.

6. LEGISLACIÓ

Quines altres referències als menors conté l'RGPD?

L'RGPD es refereix en diversos llocs als tractaments de les dades dels menors. Per exemple, en els casos següents:

- En la regulació dels interessos legítims del responsable com a **base legal** per al tractament; això no obstant, s'assenyala que no és aplicable quan prevalen els drets, les llibertats o els interessos de les persones interessades que requereixen protecció de dades personals, **especialment quan aquests interessats són nens**.
- En assenyalar que, quan els interessats són nens, la **informació** que s'ofereix en relació amb el tractament o amb l'exercici de drets ha de ser especialment **concisa, transparent, intel·ligible** i proporcionada amb llenguatge **clar i senzill**.
- En el context del **dret a l'esborrat** de les dades personals.
- En establir que les **activitats de formació i sensibilització** adreçades als nens han d'estar entre les prioritats de les autoritats de protecció de dades.
- En el context de les explicacions que ofereixen els considerants de l'RGPD, quan es refereixen a la **realització de perfils**.

6. LEGISLACIÓ

6. Dret d'informació

El nou Reglament **configura la informació com un dret** de les persones afectades i amplia les qüestions sobre les quals cal informar-les, amb els

aspectes següents:

- Les dades de contacte del **delegat de protecció de dades**;
- La base jurídica del tractament.
- Els interessos legítims perseguits en què es fonamenta el tractament, si escau.
- La intenció de transferir les dades a un tercer país o a una organització internacional i la base per fer-ho, si escau.

6. LEGISLACIÓ

- El termini durant el qual es conservaran les dades; el dret a sol·licitar la portabilitat.
- El dret a retirar en qualsevol moment el consentiment que s'hagi prestat.
- Si la comunicació de dades és un requisit legal o contractual o un requisit necessari per subscriure un contracte.
- El dret a presentar una reclamació davant una autoritat de control.
- L'existència de decisions automatitzades, inclosa la lògica aplicada i les seves conseqüències.

6. LEGISLACIÓ

Com s'ha de proporcionar la informació a les persones interessades?

L'RGPD disposa que la informació als interessats, tant respecte de les **condicions** dels tractaments que els afecten com en les **respostes** als exercicis de drets, s'ha de proporcionar de forma **concisa, transparent, intel·ligible** i de **fàcil accés**, en un llenguatge **clar i senzill**. En aquest aspecte, va més enllà del que disposa l'LOPD, que tan sols exigeix que la informació es presti de manera **expressa, precisa i inequívoca**.

Aquestes exigències impliquen que **cal evitar** acudir a **fórmules** especialment **enrevessades** i que incorporen remissions als textos legals. Cal que les clàusules informatives expliquin el contingut al quan ens referirem immediatament d'una forma clara i accessible per a les persones interessades, amb independència dels coneixements que tinguin de la matèria.

6. LEGISLACIÓ

La importància que l'RGPD concedeix a la claredat i l'accessibilitat de la informació es reflecteix en el fet que preveu que es pugui proporcionar en combinació amb **icones estandarditzades** que ofereixin una visió de conjunt del tractament previst. El disseny d'aquestes icones l'ha de fer la Comissió Europea, que ja està treballant per presentar-ne una proposta.

L'RGPD disposa que la informació a les persones interessades es faciliti per escrit, inclosos els mitjans electrònics quan escaigui.

L'Autoritat Catalana de Protecció de Dades, l'Agència Espanyola de Protecció de Dades i l'Agència Basca de Protecció de Dades estan preparant un model de clàusula informativa perquè l'utilitzin les administracions públiques. Durant el període transitori, també es presentaran directrius per a entitats privades.

6. LEGISLACIÓ

7. Drets de les persones interessades

Dreta l'oblit

L'RGPD incorpora el **dret a l'oblit** com un dret vinculat al dret de supressió, al dret a la **limitació del tractament** i al dret a la **portabilitat**:

Els interessats tenen dret a obtenir la supressió de les dades ("dret a l'oblit"), quan:

- Les dades **ja no són necessàries** per a la finalitat per a la qual es van recollir.
- Es **revoca** el consentiment en el qual es basava el tractament.
- L'interessat s'**oposa** al tractament.
- Les dades s'han tractat **il·lícitament**.
- Les dades s'han de suprimir **per complir una obligació legal**.
- Les dades s'han obtingut en relació amb l'oferta de serveis de la societat de la informació **adreçada a menors**.

6. LEGISLACIÓ

Quan el responsable ha fet públiques les dades personals i s'han de suprimir, ha d'adoptar mesures raonables per informar de la supressió els responsables que estan tractant les dades.

Es preveuen algunes **excepcions a l'exercici d'aquest dret**:

- L'exercici del dret a la llibertat d'expressió i informació.
- El compliment d'una obligació legal.
- L'existència de finalitats d'arxiu en interès públic, de recerca científica o històrica o finalitats estadístiques.
- La formulació, l'exercici o la defensa de reclamacions.
- Dret a la limitació del tractament

6. LEGISLACIÓ

Limitació de tractament

La limitació de tractament es presenta a l'RGPD com un dret de les persones interessades. Per això, no s'ha de confondre amb el bloqueig de dades actualment existent a la legislació espanyola, tot i que el fet que s'hagi inclòs com a nou dret no suposa, per si sol, que la figura del bloqueig desapareix.

La limitació de tractament suposa que, **a petició de la persona interessada, no s'aplicaran a les seves dades personals les operacions de tractament** que en cada cas correspondrien. La limitació es pot sol·licitar quan:

- La persona interessada ha exercit els drets de **rectificació** o **oposició** i mentre el responsable determina si escau atendre la sol·licitud.
- **El tractament és il·lícit**, cosa que determinaria l'esborrat de les dades, però l'interessat s'hi oposa.
- Les dades **ja no són necessàries** per al tractament, la qual cosa novament en determinaria l'esborrat, **però l'interessat sol·licita la limitació** perquè els necessita per formular, exercir o defensar reclamacions.

6. LEGISLACIÓ

A aquest dret se li apliquen els mateixos terminis i procediments que a la resta de drets previstos a l'RGPD.

Mentre duri la limitació, **el responsable només pot tractar les dades afectades**, més enllà de conservar-les, **en els casos següents**:

- Amb el **consentiment** la persona interessada.
- Per formular, exercir o defensar **reclamacions**.
- Per **protegir els drets d'una altra persona** física o jurídica.
- Per **raons d'interès públic** important de la Unió o de l'estat membre corresponent.

Una conseqüència d'aquesta regulació és que impedeix una pràctica que de vegades se segueix i que consisteix a esborrar les dades quan s'exerceixen altres drets, com el d'accés, ja que impediria l'exercici del dret a la limitació del tractament.

6. LEGISLACIÓ

Dret a la portabilitat

El dret a la portabilitat de les dades és una forma avançada del dret d'accés, per la qual **la persona interessada té dret a rebre les dades personals que l'afecten** i que ha facilitat a un responsable del tractament en un format estructurat, d'ús comú i de lectura mecànica, **i transmetre-les a un altre responsable**, si es compleixen els requisits següents:

- El tractament està basat en el consentiment o en un contracte.
- El tractament es fa per mitjans automatitzats.
- L'interessat ho sol·licita respecte de les dades que ha proporcionat al responsable i que el concerneixen, incloses les dades derivades de la pròpia activitat de l'interessat. Això suposa que no és aplicable a les dades de terceres persones que un interessat hagi facilitat a un responsable. Tampoc no s'aplica si l'interessat sol·licita la portabilitat de dades que l'incumbeixen, però que han estat proporcionades al responsable per tercers.

Inclou el dret que les dades es transmetin **directament de responsable a responsable**, si és tècnicament possible.

El grup d'autoritats europees de protecció de dades (Grup de l'article 29) ha adoptat una opinió en la qual s'analitza detalladament aquest dret.

6. LEGISLACIÓ

El grup d'autoritats europees de protecció de dades (Grup de l'article 29) ha adoptat una opinió en la qual s'analitza detalladament aquest dret.

Aquesta opinió es pot consultar aquí.

Quin és el procediment per exercir els drets recollits pel nou Reglament?

Amb caràcter general, l'RGPD exigeix als responsables que facilitin a les persones interessades l'exercici dels seus drets. Aquest mandat suposa que **els procediments i les formes** per fer-ho han de ser **visibles, accessibles i senzilles**. L'RGPD no estableix una manera concreta per exercir els drets, però sí que requereix als responsables que possibilitin que les sol·licituds es presentin per mitjans electrònics, especialment quan el tractaments'efectua per aquests mitjans.

Aquesta obligació exigeix articular procediments que permetin fàcilment **que les persones interessades puguin acreditar que han exercit els seus drets** per mitjans electrònics, cosa que actualment en moltes ocasions no és viable.

6. LEGISLACIÓ

L'RGPD preveu també que l'exercici de drets ha de ser **gratuït** per a la persona interessada. Aquest criteri de gratuïtat pot no seguir-se en els casos en què es formulen sol·licituds manifestament infundades o excessives, especialment per repetitives; en aquests casos, el responsable pot cobrar un cànon que compensi els costos administratius d'atendre la petició, o bé negar-se a actuar. **És el responsable qui ha de demostrar aquest caràcter infundat o excessiu.** En tot cas, el cànon no pot implicar un ingrés addicional per al responsable, sinó que ha de correspondre al veritable cost de la tramitació de la sol·licitud.

El responsable ha d'informar la persona interessada sobre les actuacions derivades de la seva petició **en del termini d'un mes**, que es pot ampliar dos mesos més quan es tracta de sol·licituds especialment complexes. Aquesta ampliació del termini s'ha de notificar dins del primer mes. Si el responsable decideix no atendre la sol·licitud, n'ha d'informar i motivar la negativa dins del termini d'un mes des que es va presentar.

6. LEGISLACIÓ

D'acord amb l'RGPD, els responsables han de prendre totes les mesures raonables per verificar la identitat dels afectats que sol·liciten accés i, en general, dels afectats que exerceixen la resta de drets ARCO.

El responsable que tracta una gran quantitat d'informació sobre un interessat pot demanar-li que especifiqui la informació a què es refereix la seva sol·licitud d'accés.

El **responsable** pot comptar amb la col·laboració dels **encarregats** per atendre l'exercici de drets dels interessats. Aquesta col·laboració es pot incloure en el contracte d'encàrrec de tractament.

6. LEGISLACIÓ

8. Inscripció i notificació de fitxers

L'RGPD **suprimeix**, a partir del 25 de maig de 2018, la necessitat de crear formalment els **fitxers** i **notificar-los** al registre de protecció de dades de les autoritats de control.

9. Documentació de les operacions de tractament: registre d'activitats de tractament (RAT)

L'RGPD preveu noves obligacions de **documentació del tractament** per als responsables o els encarregats del tractament. Només s'exceptuen

d'aquesta obligació els responsables o encarregats del tractament que comptin amb menys de 250 treballadors. No obstant això, **aquesta excepció no és d'aplicació** si es dona alguna de les circumstàncies següents:

- És probable **que hi hagi un risc** per als **drets i llibertats** dels subjectes afectats
- El tractament **no és ocasional**
- El tractament inclogui **categories especials de dades** o relatives a infraccions i condemnes penals.

6. LEGISLACIÓ

Aquests responsables i encarregats del tractament han de portar un registre de les activitats de tractament que duen a terme. Aquest registre ha de contenir, respecte de cada activitat, la informació que estableix l'article 30 de l'RGPD.

Aquesta informació inclou qüestions com les següents:

- Nom i dades de contacte del responsable i, si escau, del corresponsable, així com del delegat de protecció de dades si n'hi ha.
- Finalitats del tractament.
- Descripció de categories d'interessats i categories de dades personals tractades.
- Transferències internacionals de dades.
- Quan sigui possible, terminis previstos per suprimir les dades.
- Quan sigui possible, una descripció general de les mesures tècniques i organitzatives de seguretat.

6. LEGISLACIÓ

Com s'ha d'organitzar el registre d'operacions de tractament?

El registre es pot organitzar **al voltant d'operacions de tractament concretes**, vinculades a una finalitat bàsica comuna de totes elles (per exemple “gestió de clients”, “gestió comptable” o “gestió de recursos humans i nòmines”), o bé d'acord amb altres criteris diferents.

Una possibilitat per organitzar el registre d'activitats de tractament és **partir dels fitxers** que els responsables havien notificat al Registre de Protecció de Dades de Catalunya, i detallar totes les operacions que es realitzen sobre cada conjunt estructurat de dades. Podeu descarregar-vos els fitxers que teníeu declarats al registre de Protecció de Dades de Catalunya en aquest [enllaç](#).

L'APDCAT ha desenvolupat una aplicació senzilla per portar el registre d'activitats del tractament per tal que els responsables i els encarregats del tractament que ho desitgin la puguin utilitzar.

6. LEGISLACIÓ

10. Encàrrec del tractament

El Reglament amplia el **contingut mínim** del **contracte d'encàrrec** de tractament. Entre altres aspectes, el contracte ha de preveure els punts addicionals següents respecte del contingut que ja establia l'LOPD:

- L'objecte i la durada de l'encàrrec.
- La naturalesa del tractament.
- El tipus de dades personals.
- Les categories d'interessats.

6. LEGISLACIÓ

- Les obligacions i els drets del responsable.
- La previsió que les persones que han de tractar les dades es comprometen a mantenir la confidencialitat.
- L'assistència de l'encarregat al responsable per atendre les sol·licituds d'exercici de drets.
- La supressió o la devolució de les dades en finalitzar l'encàrrec.
- L'obligació de posar a disposició del responsable tota la informació necessària per demostrar que compleix les obligacions de l'encarregat del tractament i per permetre i contribuir que el responsable o un altre auditor autoritzat pel responsable efectui auditories i inspeccions.

6. LEGISLACIÓ

Obligacions específiques dels encarregats

La Directiva 95/46 i en general les lleis nacionals de transposició se centren en l'activitat dels **responsables**. L'RGPD, en canvi, conté obligacions expressament adreçades als **encarregats**. La responsabilitat última sobre el tractament continua atribuïda al responsable, que és qui determina l'existència i la finalitat del tractament. Però, en determinades matèries, **els encarregats tenen obligacions pròpies** que l'RGPD estableix, que no se circumscriuen a l'àmbit del contracte que els vincula al responsable i que les autoritats de protecció de dades han de supervisar separadament. Per exemple, els encarregats han de mantenir un **registre d'activitats de tractament**, han de determinar les mesures de seguretat aplicables als tractaments que realitzen o han de designar un delegat de protecció de dades, en els casos en què així ho preveu l'RGPD.

L'RGPD també preveu que els encarregats es puguin adherir a codis de conducta o certificar-se en el marc dels esquemes de certificació previstos en el mateix RGPD.

6. LEGISLACIÓ

L'RGPD estableix explícitament que els **responsables** només han de triar **encarregats que ofereixin garanties** suficients per aplicar mesures tècniques i organitzatives apropiades, de manera que el tractament sigui conforme als requisits del Reglament. Aquesta previsió també s'estén als encarregats, quan subcontracten operacions de tractament amb altres subencarregats.

Tot i que en el cas espanyol el Reglament de desenvolupament de l'LOPD ja estableix la necessitat de diligència deguda en la selecció dels encarregats, la novetat d'aquesta previsió de l'RGPD deriva de la seva relació amb el principi de **responsabilitat activa**. Segons aquest principi, el responsable ha d'adoptar les mesures apropiades, inclosa l'elecció d'encarregats, de manera que garanteixi i estigui en condicions de demostrar que el tractament es duu a terme conforme a l'RGPD.

6. LEGISLACIÓ

El fet que els encarregats o subencarregats s'hagin adherit a **codis de conducta** o estiguin **certificats** dins dels esquemes previstos per l'RGPD es pot utilitzar per demostrar que ofereixen les garanties suficients que el Reglament exigeix.

L'Autoritat Catalana de Protecció de Dades, l'Agència Espanyola de Protecció de Dades i l'Agència Basca de Protecció de Dades han preparat uns materials d'ajuda per redactar aquests encàrrecs, que es poden consultar [aquí](#). Aquests materials estan pensats per ajudar els responsables i els encarregats durant el període transitori fins a l'entrada en aplicació de l'RGPD. Posteriorment, i d'acord amb el que preveu el Reglament, les autoritats de protecció de dades podran elaborar clàusules model que hauran de ser aprovades pel futur Comitè Europeu de Protecció de Dades. La Comissió Europea també pot preparar clàusules contractuals model.

6. LEGISLACIÓ

Què passa amb els contractes d'encàrrec formalitzats abans de l'aplicació de l'RGPD?

Els contractes d'encàrrec formalitzats abans de l'aplicació de l'RGPD, al maig de 2018, **s'han d'adaptar** per respectar aquest contingut. Tot i que moltes de les obligacions derivades del règim establert a l'RGPD ja estan recollides a la normativa espanyola, cal modificar els contractes existents perquè les seves clàusules reflecteixin tots els continguts del Reglament, tenint en compte que les remissions genèriques a l'article de l'RGPD que els regula no són vàlides.

D'acord amb la Disposició transitòria segona del Reial Decret llei 5/2018, de 27 de juliol, de mesures urgents per l'adaptació del dret espanyol a la normativa de la Unió Europea en matèria de protecció de dades, els contractes i acords d'encàrrec del tractament establerts abans de 25 de maig de 2018 mantenen la seva vigència fins la data de venciment assenyalada en els mateixos.

Quan es tracti d'encàrrecs amb **durada indefinida**, mantenen la vigència fins al cap de **quatre anys**, a comptar des del 25 de maig de 2018.

En qualsevol cas, durant la vigència del contracte o acord, **qualsevol de les parts pot exigir a l'altra la modificació** del contracte per adaptar-la al que estableix l'article 28 de l'RGPD.

6. LEGISLACIÓ

11. Avaluacions d'impacte relatives a la protecció de dades

Quan un tractament, per la seva naturalesa, abast, context o fins suposi un **alt risc pels drets i llibertats de les persones físiques**, especialment quan s'utilitzin **noves tecnologies**, el responsable ha de fer abans una **avaluació de l'impacte en la protecció de dades** (AIPD).

L'article 35.3 de l'RGPD estableix que, entre d'altres supòsits, cal fer una avaluació d'impacte relativa a la protecció de dades en els següents supòsits:

*“a) Avaluació sistemàtica i exhaustiva d'aspectes personals de persones físiques basada en un **tractament automatitzat**, com l'elaboració de perfils, sobre la base de la qual es prenen decisions que produeixen efectes jurídics per a les persones físiques o que les afecten significativament de manera similar.*

*b) Tractament a gran escala de les **categories especials de dades** a què es refereix l'article 9, apartat 1, o de les dades personals relatives a **condemnes i infraccions penals** a què es refereix l'article 10.*

*c) **Observació sistemàtica a gran escala** d'una zona d'**accés públic**. ”*

6. LEGISLACIÓ

Per determinar què s'ha d'entendre per “**gran escala**”, es pot tenir en compte que el Grup de l'article 29, en el seu dictamen sobre la designació de delegats de protecció de dades, considera que per valorar si el tractament es fa a gran escala s'ha de tenir en compte el següent:

- El nombre d'interessats afectats, ja sigui en termes absoluts o com a proporció d'una determinada població.
- El volum i la varietat de dades tractades.
- La durada o permanència de l'activitat de tractament.
- L'extensió geogràfica de l'activitat de tractament.

6. LEGISLACIÓ

Més enllà dels supòsits previstos directament a l'RGPD, aquesta Autoritat, en els tractaments que no siguin transfronterers, considera que **cal fer una avaluació** de l'impacte relativa a la protecció de dades en els tractaments que es vulguin dur a terme que compleixin **dues o més de les circumstàncies següents**:

- Avaluació o “puntuació” de persones, inclosa l'elaboració de perfils i la predicció de conductes o comportaments.
- Presa de decisions automatitzada amb efecte jurídic o similar significatiu.
- Observació sistemàtica.
- Dades sensibles o dades molt personals (categories especials de dades de l'article 9 RGPD o dades personals relatives a condemes i infraccions penals a que es refereix l'article 10 RGPD).
- Tractaments de dades a gran escala.

6. LEGISLACIÓ

- Associació o combinació de conjunt de dades que poden excedir les expectatives raonables de les persones interessades.
- Dades relatives a subjectes vulnerables (menors, empleats, persones discapacitades, persones grans, sol.licitants d'asil o refugiats, etc.).
- Utilització innovadora o aplicació de noves solucions tecnològiques o organitzatives.
- Quan el tractament impedeix a les persones afectades exercir un dret, utilitzar un servei o executar un contracte.

Aquesta llista recull les Directrius sobre l'avaluació d'impacte relativa a la protecció de dades (AIPD) i per determinar si el tractament comporta probablement un alt risc a efectes del Reglament (UE) 2016/679, adoptades pel Grup de Treball de l'Article 29 el 4 d'abril de 2017 (en endavant, WP 248) i assumides pel Comité Europeu de Protecció de dades en la seva reunió de 25 de maig de 2018.

6. LEGISLACIÓ

Aquesta llista no és exhaustiva i s'anirà actualitzant. **Si una operació de tractament no hi figura no significa que no es requereixi fer l'AIPD.**

Cal verificar sempre que el tractament no suposa un alt risc pels drets i llibertats de les persones, especialment si s'utilitza noves tecnologies.

Aquests criteris són d'aplicació no només als **responsables** que vulguin dur a terme algun dels tractaments inclosos, sinó també als **òrgans i institucions** que elaborin un projecte de disposició normativa que comporti algun d'aquests tractaments. En aquest cas, si el projecte normatiu s'ha sotmès a una avaluació d'impacte relativa a la protecció de dades no serà necessari que l'elaborin després els responsables del tractament.

6. LEGISLACIÓ

Un cop realitzada l'AIPD, el responsable ha de formular, amb caràcter previ a l'inici del tractament, una consulta a aquesta Autoritat (https://seu.apd.cat/ca/tramits/consulta_previa), llevat que l'existència d'alt risc pels drets i llibertats de les persones s'hagi pogut mitigar amb l'adopció de mesures tècniques i organitzatives adequades.

Per a més informació podeu consultar les Directrius del Grup de treball de l'article 29 sobre l'avaluació d'impacte relativa a la protecció de dades (AIPD) i per determinar si el tractament comporta probablement un alt risc a efectes del Reglament (UE) 2016/679 (WP 248), assumides pel Comité Europeu de Protecció de dades en la seva reunió de 25 de maig de 2018, i la Guia pràctica de l'APDCAT sobre l'avaluació d'impacte relativa a la protecció de dades al RGPD.

6. LEGISLACIÓ

Què succeeix amb els tractaments iniciats abans del 25 de maig de 2018 als quals amb la nova normativa els sigui exigible l'avaluació d'impacte sobre la protecció de dades (EIPD)?

Si aquests tractaments es perllonguen més enllà del 25 de maig de 2018 i l'anàlisi de risc que les organitzacions duen a terme sobre els tractaments iniciats amb anterioritat indica que aquests tractaments presenten alt risc per als drets o les llibertats les persones interessades, la Guia per a

l'avaluació de l'impacte en la protecció de dades adoptada pel Grup de Treball de l'article 29 **també recomana fer una DPIA** *“per als tractaments de dades que han tingut lloc abans de maig de 2018 i els quals, per tant, no estan subjectes a una DPIA, per assegurar-se que 3 anys després d'aquesta data o abans, depenent del context, els riscos per als drets i llibertats estan sent mitigats”*.

6. LEGISLACIÓ